

Capítulo 01

Fundamentos de la Seguridad de la Información

Objetivos

Explicar las definiciones más importantes y preocupaciones comunes a considerar en términos de seguridad de la información en las organizaciones, seleccionar servicios y controles para la seguridad de la información e identificar los factores críticos de éxito.

Conceptos

Servicios de seguridad, gestión de seguridad de la información, amenazas, vulnerabilidades, ataques y controles.

1.1 Tendencias en el área de la “gestión de seguridad de información”

La gestión de seguridad de la información viene evolucionando desde sus albores como norma ISO-17799 del año 2000, hasta convertirse en la familia ISO 27000 desde el 2005 pretendiendo ser una norma internacional que ofrece recomendaciones para realizar la gestión de la seguridad de la información. Esta norma está dirigida a los responsables de iniciar, implantar o mantener la seguridad de la información de una organización.

La norma ISO 27001 está orientada a establecer, implementar, operar, monitorear, analizar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información, SGSI y está alineada con la norma ISO 9001 con el fin de apoyar la implementación y operación, consistente e integrada con sistemas de gestión relacionados. Es decir, consolidar diversos sistemas de gestión de las organizaciones en uno sólo sistema integrado, optimizando sus procesos y facilitando el tránsito de información entre ellos.

En octubre del 2013 se ha actualizado la norma de requisitos del SGSI denominada ISO27001:2013 así como también la norma del Código de Práctica del Sistema de Gestión de Seguridad de la Información denominada ISO27002:2013.

La edición 2013 de la norma ISO27001 proporciona un enfoque común y una estructura para las normas de los sistemas de gestión que se presta más fácilmente para la integración con otras normas de sistemas de gestión. La norma actualizada ISO-27001 cuenta con 114 controles en 14 categorías o dominios, en contraste con los 133 controles y 11 categorías contenidas en la edición 2005. Los requerimientos para el análisis de riesgos están alineados con la norma ISO 31000 para la gestión del riesgo.

La norma ISO-27002 proporciona las directrices para las normas de seguridad de la información de la organización y las prácticas de gestión de seguridad de la información, incluyendo la selección, implementación y gestión de los controles, considerando el entorno de riesgos de seguridad de la información de la organización. El nuevo código de prácticas ha sido alineado, en cuanto al número de controles, con los de la norma ISO/IEC 27001, así como la terminología con la de la norma ISO/IEC 27000. Refleja la estructura del Anexo A de la norma ISO/IEC 27001:2013.

1.2 ¿Por qué preocuparse por la seguridad?

Problemas comunes:

- » Destrucción de la información y otros recursos.
- » Modificación o distorsión de información.
- » Robo, eliminación o pérdida de información u otros recursos.
- » La revelación de información.
- » La interrupción de los servicios.

Preguntas:

- » ¿Qué es seguridad para usted?
- » ¿Qué entiende por seguridad de la información?

La seguridad de la información es fundamental para la supervivencia de las organizaciones en la era de la información. Varios problemas están involucrados, dado que la sociedad depende de la información almacenada en los sistemas informáticos para la toma de decisiones en las empresas, entidades del gobierno, entre otros contextos organizacionales.

La información puede existir en varios formatos: impresa, almacenada electrónicamente, hablada, transmitida por correo convencional de voz o electrónico, etc. Cualquiera que sea el formato o medio de transmisión o almacenamiento, se recomienda proteger la información de manera adecuada. Por lo tanto, es responsabilidad de la seguridad de la información protegerla de los diversos tipos de amenazas para garantizar

la continuidad del negocio, minimizar el riesgo y maximizar el retorno sobre la inversión.

Afortunadamente, hay una conciencia creciente de organizaciones de todo el valor y la vulnerabilidad de las actividades de sus activos con respecto a la seguridad. Hoy en día, la seguridad de la información es crucial para asegurar la competitividad, la rentabilidad, el cumplimiento de los requerimientos legales y la imagen de la organización en el mercado de las organizaciones, tanto en el sector público como en el sector privado. En tales contextos, la seguridad de la información es un componente que viabiliza negocios, tales como e-government (gobierno electrónico) y el e-commerce (comercio electrónico).

1.3 Definiciones

La seguridad de la información incluye la protección de información, sistemas, recursos y demás activos contra desastres, errores (intencionales o no) y manipulación no autorizada, para reducir la probabilidad y el impacto de los incidentes de seguridad.

De acuerdo con la norma ISO/IEC 27002, la seguridad de la información es la protección de la información contra los diversos tipos de amenazas para garantizar la continuidad del negocio, minimizando los riesgos y maximizando el retorno sobre la inversión y las oportunidades de negocio. La seguridad de la información se obtiene como resultado de la implementación de un conjunto de controles, que comprenden políticas, procesos, procedimientos, estructuras organizacionales y funciones de hardware y software.

En particular, los controles deben ser establecidos, implementados, monitoreados, evaluados y mejorados continuamente con el fin de cumplir con los objetivos del negocio y la seguridad de la organización. La identificación de los controles adecuados requiere una planificación detallada. A continuación se especifican algunos conceptos:

- » **Incidente de seguridad:** corresponde a cualquier evento adverso relacionado con la seguridad, por ejemplo, ataques de denegación de servicio (*Denial of Service*, DoS), robo de información, fuga y la obtención de un acceso no autorizado a la información.
- » **Activo:** cualquier elemento que tenga valor para la organización y su negocio. Algunos ejemplos: bases de datos, software, equipos (computadores, *notebooks*), servidores, dispositivos de red (*routers*, *switches*, etc), personas, procesos y servicios.

- » **Amenaza:** cualquier evento que explote vulnerabilidades. Causa potencial de un incidente no deseado, que puede resultar en daños a un sistema u organización (véase el punto 2.16 NTC ISO/IEC 27002:2007).
- » **Vulnerabilidad:** cualquier debilidad que puede ser explotada y ponga en peligro la seguridad de los sistemas y datos. Fragilidad de un activo o grupo de activos que pueden ser explotados por una o más amenazas (véase el punto 2.17 NTC ISO / IEC 27002:2007). Las vulnerabilidades son fallas que permiten la aparición de deficiencias en la seguridad general del equipo o de la red. Configuraciones incorrectas en el equipo o en la seguridad también permiten la creación de vulnerabilidades. A partir de esta falla, las vulnerabilidades son explotadas por amenazas que cuando se materializan, causan daños al computador, a la organización o a los datos personales.
- » **Riesgo:** combinación de la probabilidad (oportunidad de que la amenaza se materialice) de que ocurra un evento y sus consecuencias para la organización. Algo que puede ocurrir y sus efectos sobre los objetivos de la organización.
- » **Ataque:** cualquier acción que comprometa la seguridad de una organización.
- » **Impacto:** resultado evaluado de un evento en particular.

Repaso:

- » ¿Explique qué son activos para usted?
- » ¿Cómo explicaría en su organización el término “vulnerabilidad”?

1.4 Modelos de ataque

Hay cuatro modelos posibles de ataque:

- » **Interrupción:** cuando un activo se destruye o queda indisponible (o inutilizable), caracterizando un ataque contra la disponibilidad. Por ejemplo, la destrucción de un disco duro.
- » **Intercepción:** cuando se accede a un activo por un tercero no autorizado (persona o programa del computador), caracterizando un ataque contra la confidencialidad. Por ejemplo, la copia no autorizada de archivos o programas.

- » **Modificación:** cuando se accede a un activo por un tercero no autorizado (persona o programa del computador) y se modifica, materializando un ataque contra la integridad. Por ejemplo, cambio de los valores en un archivo de datos.
- » **Fabricación:** cuando una parte no autorizada (persona o programa del computador) inserta objetos falsificados en un activo, configurando un ataque contra la autenticidad. Por ejemplo, la adición de registros en un archivo.

En la Figura 1, se observa el flujo normal de la información de una fuente a un destino (a). En secuencia, se presentan cada uno de estos modelos de posibles ataques: una interrupción (b), interceptación (c), modificación (d) y fabricación (e).

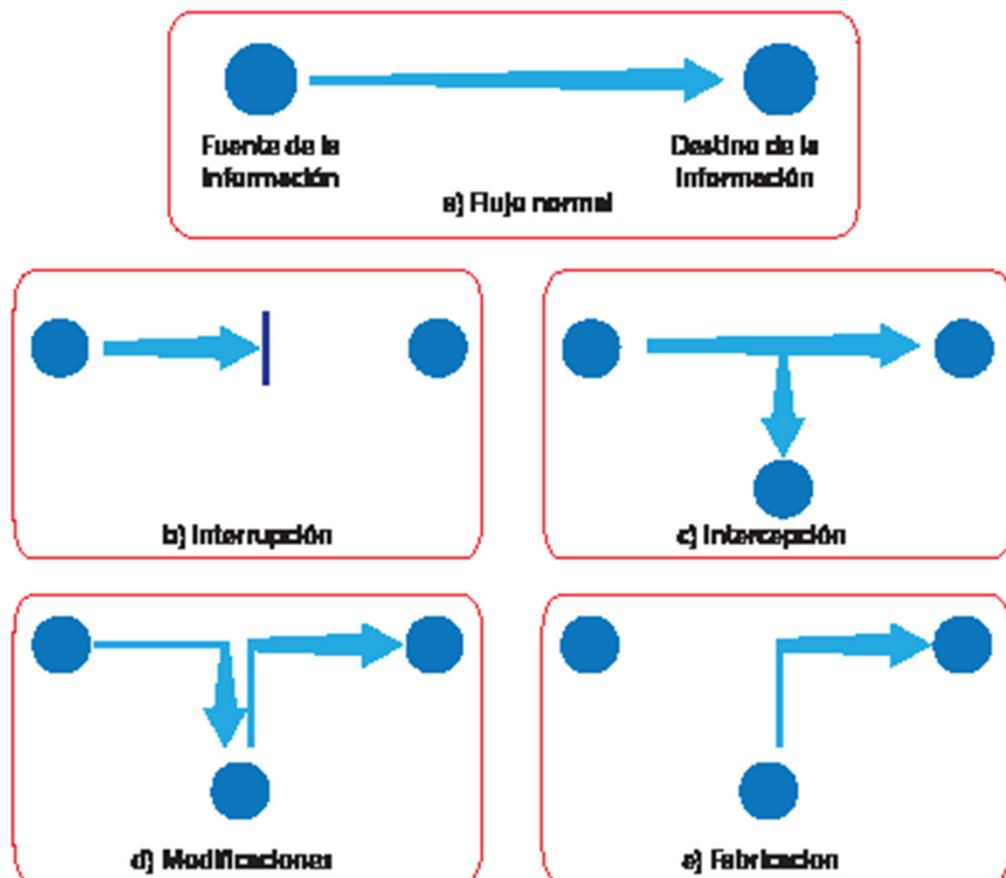


Figura 1.
Modelos
de ataque

Ejercicio de refuerzo - modelos de ataque

- » Explique el modelo de ataque de la interceptación.

1.5 Formas de ataque

El ataque es un acto deliberado de tratar de esquivar los controles de seguridad con el objetivo de explotar las vulnerabilidades. Existen los siguientes tipos de ataque:

- » **Ataques pasivos:** ataques basados en escuchar y monitorear las transmisiones, con el fin de obtener la información que se está transmitiendo. Escuchar una conversación telefónica es un ejemplo de esta categoría. Los ataques de esta categoría son difíciles de detectar debido a que no implica cambios en los datos, sin embargo, son posibles de prevenir con el uso de la criptografía.
- » **Ataques activos:** involucran la modificación de datos, la creación de objetos falsos o negación de servicio, y tienen las propiedades opuestas de ataques pasivos. Son ataques difíciles de prevenir debido a la necesidad de una protección completa de todas las instalaciones de comunicaciones y procesamiento, durante todo el tiempo. Por lo tanto, es posible detectarlos y aplicar una medida para la recuperación de los perjuicios causados.

Ejercicio de refuerzo - formas de ataque

- » Explique cómo ocurriría un ataque activo en el entorno de su organización.

1.6 Arquitectura de seguridad

Arquitectura de seguridad propuesta por el modelo *Open Systems Interconnection*, OSI (Interconexión de Sistemas Abiertos) definida en la Norma ISO 7498-2 establece los siguientes objetivos y requisitos de seguridad:

- » Proteger los datos contra modificaciones no autorizadas.
- » Proteger los datos contra pérdida / robo / hurto.
- » Proteger los datos contra toda divulgación no autorizada.
- » Asegurar la identidad del remitente correcto de los datos.
- » Asegurar la identidad del destinatario correcto de los datos.

1.7 Servicios de seguridad

En este tema, son tratados los objetivos y las categorías de los servicios de seguridad que son considerados en el contexto de seguridad de la información. De acuerdo con la norma ISO 7498-2, que incluye los aspectos relacionados con la seguridad en el modelo de OSI, los servicios de seguridad son medidas preventivas elegidas para hacer frente a las amenazas identificadas. Los servicios de seguridad aumentan la seguridad de la información frente a ataques haciendo uso de uno o más mecanismos de seguridad. En la literatura estos servicios también son citados como los principios básicos de seguridad.

Los servicios y mecanismos de seguridad deben aplicarse con el fin de cumplir con los requisitos de seguridad de la organización, teniendo en cuenta el equilibrio entre las necesidades de seguridad y los costos respectivos. En particular, para identificar y dar prioridad a los servicios de seguridad, es esencial analizar los riesgos y los impactos probables que comprenden a toda la organización en cuestión.

- » **Confidencialidad:** comprende la protección de los datos transmitidos contra ataques pasivos, es decir, el acceso no autorizado, que incluirá medidas tales como el control de acceso y encriptación. La pérdida de la confidencialidad se produce cuando hay una violación de la confidencialidad de cierta información (por ejemplo, la contraseña de un usuario o administrador del sistema) permitiendo que quede expuesta la información restringida, las cuales estaban disponibles sólo a un determinado grupo de usuarios.
- » **Autenticidad:** está interesada en garantizar que la comunicación sea auténtica, es decir, origen y destino pueden verificar la identidad de la otra parte implicada en la comunicación, con el fin de confirmar que la otra parte es quien dice ser. El origen y el destino son normalmente usuarios, dispositivos o procesos.
- » **Integridad:** es la garantía contra ataques activos a través de los cambios o de remociones no autorizadas. Es importante utilizar un esquema que permite la verificación de la integridad de los datos almacenados y su transmisión. La integridad puede ser considerada bajo dos aspectos: servicio sin y con recuperación. Una vez que los ataques activos son considerados en su contexto, la detección, en lugar de la prevención, es lo que importa, así, si se detecta un peligro para la integridad, puede ser reportado y el mecanismo de recuperación se activa inmediatamente. La integridad es también un prerrequisito para otros servicios de seguridad. Por ejemplo, si la integridad de un sistema de control de acceso a un sistema operativo es violada, también se viola

- la confidencialidad de sus archivos. La pérdida de la integridad se produce en un momento en que cierta información está expuesta a la manipulación por personal no autorizado, que hace cambios que no fueron aprobados y no están bajo el control del propietario de la información (corporativo o privado).
- » **No repudio:** comprende el servicio que impide a una fuente o destino negar la transmisión de mensajes, es decir, cuando se envía el mensaje dado, el destino puede demostrar que éste fue enviado realmente por determinado origen y viceversa.
 - » **Conformidad:** deber de cumplir y hacer cumplir las regulaciones internas y externas impuestas a las actividades de la organización. Estar en conformidad es estar de acuerdo, siguiendo y haciendo cumplir las leyes y reglamentos internos y externos.
 - » **Control de acceso:** trata de limitar y controlar el acceso lógico / físico a los activos de una organización a través del proceso de identificación, autenticación y autorización, con el fin de proteger los recursos contra el acceso no autorizado.
 - » **Disponibilidad:** determina que los recursos estén disponibles para el acceso por parte de entidades autorizadas, siempre que lo soliciten, representando la protección contra la pérdida o degradación. La pérdida de la disponibilidad sucede cuando la información deja de estar accesible para aquellos que la necesitan. Sería el caso de pérdida de comunicación con un sistema importante para la organización, que ocurrió al caer un servidor o una aplicación crítica para el negocio, que presentó una falla debido a un error causado por motivo interno o externo al equipo o por la acción de personas no autorizadas, con o sin intención maliciosa.

Ejercicio de refuerzo - servicios de seguridad

- » Explique cómo protegería la confidencialidad
- » Explique qué viene a ser autenticidad e integridad.

1.8 Seguridad de la información

En este tema, se detallan los principales aspectos relacionados con la gestión de la seguridad de la información, con la presentación de un panorama general de las preocupaciones, responsabilidades y actividades involucradas.

La Figura 2 presenta una visión general de la seguridad de la información. Los cambios tecnológicos son una presencia constante en la vida diaria de la organización. Estos cambios pueden hacer que surjan nuevas vulnerabilidades y riesgos, o agravar los ya existentes, por lo cual deben ir acompañados de una evaluación de riesgos dinámica y actualizada, lo que permite el levantamiento de los niveles de riesgo y la forma de tratarlos.

Figura 2.
Visión general
de la seguridad de la
información



Al mismo tiempo, es necesario conocer las leyes que la organización está obligada a seguir y recopilar los requisitos de seguridad necesarios para cumplir con ella, y a partir de estos requisitos legales, identificar los controles necesarios y los designados por el análisis de riesgos, con el uso de las normas de seguridad. A partir de los controles identificados, es necesario generar políticas, normas y procedimientos para la aplicación de los controles.

1.9 Preparando a la organización

Antes de pensar en la gestión de la seguridad de la información en una organización, hay que tener en cuenta las respuestas a las siguientes preguntas:

- » ¿Qué hay que proteger? Los activos de la organización requieren protección.
- » ¿Contra qué o quién? ¿Cuáles son las amenazas que pueden afectar a la organización y cómo y quién puede explotar estas amenazas?
- » ¿Cuál es la importancia de cada recurso? Cada recurso de la información participa en el proceso de negocio de la organización.

Proceso de negocio: conjunto de acciones y actividades que coexisten e interactúan de una manera lógica y coherente para desarrollar un entregable (producto) que cumpla con los requisitos de calidad y las expectativas del cliente, ya sea interno o externo.

- » ¿Cuál es el grado de protección deseado?
- » ¿Qué requisitos de protección el negocio exige y qué nivel de protección es necesario?
- » ¿Cuánto tiempo, recursos financieros y humanos, usted desea gastar para alcanzar los objetivos de seguridad deseados?
- » ¿Qué recursos están disponibles para los objetivos de seguridad y qué se puede hacer con los recursos existentes?
- » ¿Cuáles son las expectativas de los directivos, clientes y usuarios en materia de seguridad de la información?
- » ¿Qué esperan de la seguridad de la información para el negocio de la organización?

Con las respuestas a estas preguntas, usted puede continuar con el proceso de establecimiento de la seguridad de la información y su gestión en la organización.

1.10 Requisitos de seguridad

Hay tres fuentes principales a tener en cuenta al establecer los requisitos de seguridad de la información de una organización:

- » **Evaluación/análisis de riesgos:** considera los objetivos y estrategias de negocio de la organización, lo que resulta en la identificación de las vulnerabilidades y las amenazas a los activos. En este contexto, se tiene en cuenta la probabilidad de ocurrencia de las amenazas y el impacto en el negocio.
- » **Legislación vigente:** estatutos, reglamentos y las cláusulas contractuales que deben cumplirse para la organización, sus socios, subcontratistas y proveedores.
- » **Conjunto de principios:** los objetivos y requisitos de negocios para el procesamiento de datos que la organización debe definir para dar soporte a sus operaciones.



Para mayor información consulte la norma ISO 27002:2007.

1.11 Análisis/evaluación de riesgos

En el análisis/evaluación de riesgo, los gastos en los controles deben ser equilibrados en función del impacto que causará posibles fallas de seguridad en los negocios. Por lo tanto, se debe realizar periódicamente el análisis/evaluación con el fin de contemplar cambios en la organización.

Estos resultados ayudarán a determinar y direccionar las acciones gerenciales y las prioridades para la gestión del riesgo de seguridad de la información. La evaluación compara el riesgo estimado con los criterios predefinidos para determinar la importancia o el valor del riesgo para la organización.



Más información consulte la norma NTC ISO/IEC 27005:2008

1.12 Selección de controles

Tras la identificación de los requisitos de seguridad, el análisis/evaluación de riesgos y la toma de decisiones con respecto al tratamiento del riesgo en una organización, se pueden finalmente, seleccionar e implementar los controles adecuados.

Los controles son medidas o conjunto de medidas adoptadas para hacer frente a las vulnerabilidades y reducir el riesgo de incidentes de seguridad de la información. El control, también conocido como contramedida, es cualquier mecanismo útil para gestionar los riesgos, incluyendo las políticas, procedimientos, directrices, prácticas o estructuras organizativas que pueden ser de carácter administrativo, técnico, de gestión o legal.

Los controles se pueden seleccionar a partir de normas preestablecidos (por ejemplo, las normas NTC ISO/IEC 27002:2007 Y NTC ISO / IEC 27001:2006) o de un conjunto de controles específicos de la organización. En particular, los controles seleccionados deben estar de acuerdo con las leyes y regulaciones nacionales e internacionales vigentes relevantes para la seguridad de la información y para los negocios de la organización.

Algunos ejemplos de control:

- » Las barreras, puertas, carteles de “prohibido entrar”, torniquetes;
- » Tarjetas de control de visitantes, circuito cerrado de televisión;
- » contraseñas, cerraduras, controles biométricos;
- » Las políticas de seguridad, manual de responsabilidad, entrenamiento;
- » Antivirus, copias de seguridad, control de acceso lógico.

Control biométrico:

El uso de la biometría para identificar o verificar el acceso a recursos tales como computadores, *notebooks*, teléfonos inteligentes, redes de computadores, aplicaciones, bases de datos y otros hardware y software que necesitan tener su acceso protegido. La biometría es el uso de las características físicas o de comportamiento de las personas como una forma de identificarlas.

Ejercicio de refuerzo - selección de controles

- » Explique qué son los controles.

1.13 Los controles de seguridad de la información

El control, por definición, es una forma de gestionar el riesgo y puede incluir políticas, procedimientos, directrices y prácticas que pueden ser de carácter administrativo, técnico, legal o de gestión. Algunos controles pueden ser considerados como “primeros pasos” para la seguridad de la información en las organizaciones, con base en requisitos legales y / o mejores prácticas para la seguridad de la información.

Desde el punto de vista legal, existen controles considerados fundamentales y dependen de la legislación vigente, es decir:

- » Protección de datos y privacidad de la información personal;
- » Protección de los registros de la organización;
- » Derechos de propiedad intelectual.

Los controles considerados buenas prácticas para la seguridad de la información son:

- » Documento de la política de seguridad de la información;
- » Asignación de responsabilidades para la seguridad de la información;
- » Sensibilización, educación y capacitación en seguridad de la información;
- » Procesamiento correcto en las aplicaciones;
- » Gestión de las vulnerabilidades técnicas;
- » Gestión de la continuidad del negocio;
- » Gestión de incidentes de seguridad de la información.

Es importante que la selección o no de un control determinado sea una acción basada en los riesgos específicos de la organización. Por lo tanto, tenga en cuenta los controles designados como punto de partida, dado que no sustituyen a la selección de los controles basados en el análisis/ evaluación de riesgos.

Es notorio, sin embargo, la concientización de que una política de seguridad de la información no debe ser definida en términos generales. Las

organizaciones deben ser analizadas caso por caso, con el fin de identificar sus necesidades de seguridad y así desarrollar e implementar una política adecuada. Además, la política debe asignar derechos y responsabilidades a las entidades que tienen que ver directamente con la información y recursos informáticos de las organizaciones. Por lo que cualquier evento que resulte en violación de la política se considera un incidente de seguridad.

Otra cuestión a considerar es la gestión de la continuidad del negocio, lo que tiene que ver con los planes de contingencia y continuidad, con énfasis en la planeación para asegurar la recuperación de desastres.

Ejercicio de refuerzo - los controles de seguridad de la información

- » ¿Cuáles son los controles que se consideran esenciales desde el punto de vista legal?
- » En su organización, ¿qué controles aplicados se consideran como mejores prácticas?

1.14 Elementos relevantes para la seguridad de la información

La gestión de seguridad de la información fomenta la adopción de políticas, procedimientos, directrices y otros elementos pertinentes cuyo alcance debe comprender la gestión del riesgo sobre la base de costo / beneficio para la organización.

En este contexto, para la gestión de la seguridad de la información, los elementos siguientes son relevantes:

- » Política de seguridad de la información.
- » Seguridad organizacional.
- » Gestión de activos.
- » Seguridad de recursos humanos.
- » La seguridad física y del ambiente.
- » Gestión de las operaciones y comunicaciones.
- » Control de acceso.
- » Gestión de incidentes de seguridad de la información.
- » Gestión de la continuidad del negocio.

Todos los elementos son tratados en detalle en la norma NTC ISO/IEC 27002:2007 y se explicarán en este curso.

1.15 Actividades relacionadas

Actividades adicionales consideradas en el ámbito de la gestión de seguridad de la información:

- » Gestión de la seguridad de los sistemas, que abarca todos los aspectos de la seguridad de los sistemas de una organización, tales como la administración de la política de seguridad, procedimientos de recuperación de desastres, entre otros. Es responsabilidad de esta gestión actualizarse constantemente con respecto a los problemas, los riesgos y las soluciones de seguridad más recientes.
- » Gestión de los servicios de seguridad, incluyendo la selección de los mecanismos de seguridad más adecuados para atenderlos.
- » Gestión de los mecanismos de seguridad disponibles para cumplir los requisitos de seguridad de la organización.
- » Gestión de la auditoría de seguridad, revisión y verificación de registros y eventos de seguridad, con el objetivo de evaluar la idoneidad de los controles del sistema, su adhesión a la política de seguridad, y recomendar cambios apropiados / necesarios a los controles empleados en la organización.

1.16 Factores críticos para el éxito de la seguridad de la información

Los siguientes son algunos de los factores que son críticos para el éxito de la seguridad de la información en las organizaciones:

- » La política de seguridad de la información, los objetivos y las prácticas deben reflejar los objetivos de negocio de la organización.
- » El enfoque y la estructura que han sido adoptados para la ejecución, el mantenimiento, el seguimiento y la mejora de la seguridad de la información deben ser compatibles con la cultura de la organización.
- » Todos los niveles gerenciales de la organización deben estar comprometidos y apoyar la seguridad de la información.

- » Los requisitos de seguridad de la información, el análisis, la evaluación y la gestión del riesgo deben ser bien entendidos (en detalle).
- » La seguridad de la información debe darse a conocer, de manera eficiente, a todas las entidades de la organización (presidentes, directores, gerentes, empleados, contratistas, etc.).
- » Distribución y comunicación de directrices, políticas y normas para todas las partes involucradas
- » Suministro de recursos financieros para la gestión de seguridad de la información.
- » Suministro de sensibilización, entrenamiento y educación adecuadas.
- » Establecimiento de un proceso eficiente para la gestión de incidentes de seguridad
- » Implementación de un sistema de medición de la gestión de seguridad de la información.
- » Todos los elementos de la política de seguridad deben ser distribuidos y comunicados a las entidades de la organización.
- » Los recursos financieros se deben proporcionar para la gestión de seguridad de la información.
- » Medios de sensibilización, formación y educación adecuada deben ser provistos.
- » Se debe establecer un procedimiento eficaz para la gestión de incidentes de seguridad de la información.
- » Se debe implementar un mecanismo para medir y evaluar la eficacia de la gestión de seguridad de la información, con las sugerencias de mejora posteriores (véase el punto 0.8 de la norma NTC-ISO/IEC 27002:2007).

La gestión del riesgo

Involucra actividades para dirigir y controlar una organización en términos de riesgos. Por lo tanto, comprende el análisis, la evaluación, el tratamiento y la aceptación de los riesgos.

Capítulo 02

Código de buenas prácticas

Objetivos

Conocer la norma NTC-ISO/IEC 27002:2007 y seleccionar, relacionar y combinar sus controles.

Conceptos

Estructura y secciones de la norma NTC-ISO/IEC 27002:2007 y sus objetivos.

2.1 Estructura de la norma

La norma NTC-ISO/IEC 27002 fue preparada para servir como una guía práctica para el desarrollo y la aplicación de los procedimientos y controles de seguridad de la información en una organización.

Ejercicio de nivelación - fundamentos de la seguridad de la información

» ¿Qué entiende usted por código buenas de prácticas?

Está estructurada para proporcionar un código de buenas prácticas para la gestión de la seguridad, la norma está organizada en capítulos de 0 a 15. En los capítulos 0-4 se presentan los temas de introducción (0), el objetivo de la norma (1), los términos y las definiciones adoptadas por la norma (2), la estructura de la norma (3) y el análisis / evaluación y tratamiento de riesgos (4), y son considerados como la sección introductoria.

Desde el capítulo 5, la norma llama a cada capítulo como sección. Por lo tanto, hay once secciones específicas que ofrecen los códigos de práctica de la gestión de la seguridad.

Para cada sección, existe al menos una categoría importante de la seguridad. Las once secciones forman un total de 39 categorías principales de seguridad. En la sección 3 de la norma son presentadas las secciones y la cantidad de categorías por cada sección. Cada categoría presenta un objetivo de control y uno o más controles que deben aplicarse con el fin de alcanzar el objetivo de control.

Hay 133 controles y ellos son los elementos que definen lo que la norma 27002 considera importante para un proceso de seguridad de la información. Los controles identificados por números (xx.xx.xx) son estructurados a través de:

- » **Control:** descripción y definición de control;
- » **Directrices para la implementación:** información auxiliar en la implementación del control;
- » **Información adicional:** informaciones complementarias.

Todo el trabajo de este capítulo será desarrollado con el manejo y la lectura de los temas presentados en la norma NTC-ISO/IEC 27002.



Figura 3.
Secuencia
estructural
de la norma

En el sentido horario, se observa la secuencia estructural de la norma, destacando las once secciones de controles de seguridad de la información (secciones 5-15).

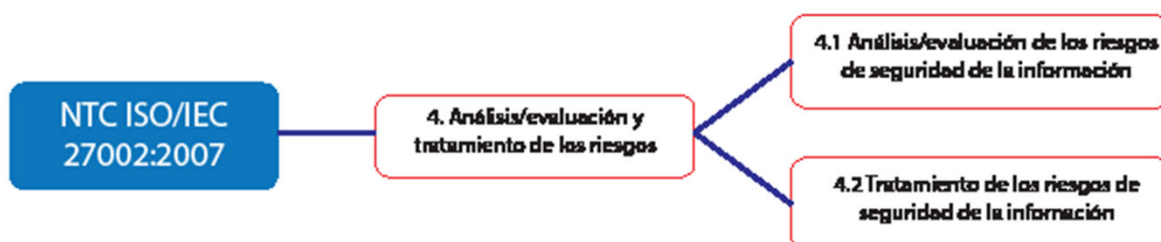


Más información se puede encontrar en la norma ISO27002:2007

2.2 Sección 4: análisis/evaluación y tratamiento de los riesgos

Figura 4.
Sección 4:
análisis/
evaluación y
tratamiento
de riesgos

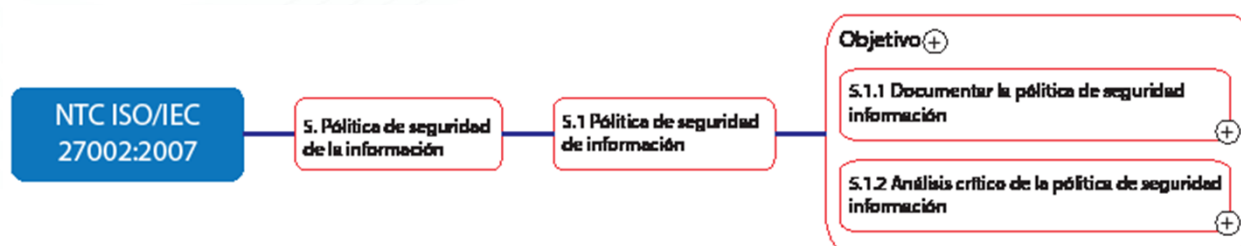
La sección 4 (análisis/evaluación y tratamiento de riesgos) es una sección introductoria que presenta objetivamente la importancia del análisis de riesgos para la organización, y las indicaciones generales de la forma en que debe hacerse.



2.3 Sección 5: política de seguridad

Figura 5.
Sección 5.1:
política de
seguridad de
la información

La sección 5 de la norma se refiere a la política de seguridad de la información. El objetivo de la categoría de control es proporcionar orientación y apoyo de gestión para la seguridad de la información, mediante el establecimiento de una política clara y objetiva, alineada con los objetivos de negocio de la organización. La sección 5 muestra la forma en que debe ser generado y actualizado el documento de la política.



Esta sección se compone de una categoría principal de seguridad (5.1: política de seguridad de la información) y dos controles (5.1.1 y 5.1.2).

El control 5.1.1 (documento de la política de seguridad de información) muestra, en las "Directrices para la implementación", lo que conviene que el documento de política contenga y la importancia de que sea comunicado a todos.

El control de 5.1.2 (análisis crítico de la política de seguridad de la información) presenta como corresponde que se realice el análisis crítico por parte de la dirección de la organización.

Ejercicio de refuerzo - sección 5: política de seguridad

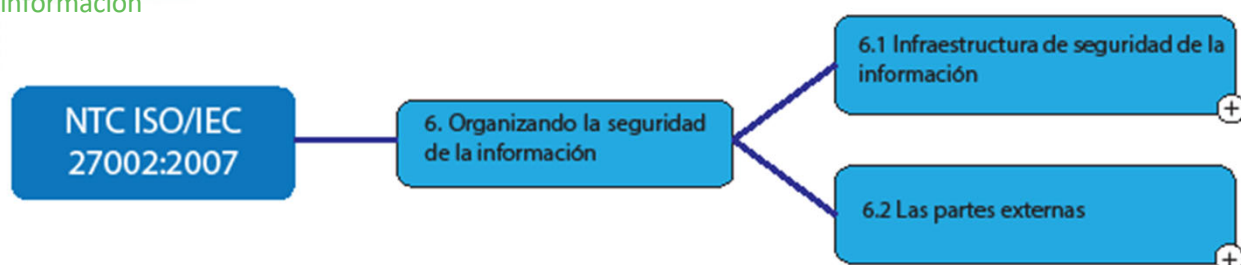
Utilizando la norma, explique:

- » El objetivo de la categoría de control 5.1
- » La letra b de las directrices para la implementación del control 5.1.1

2.4 Sección 6: organizando la seguridad de la información

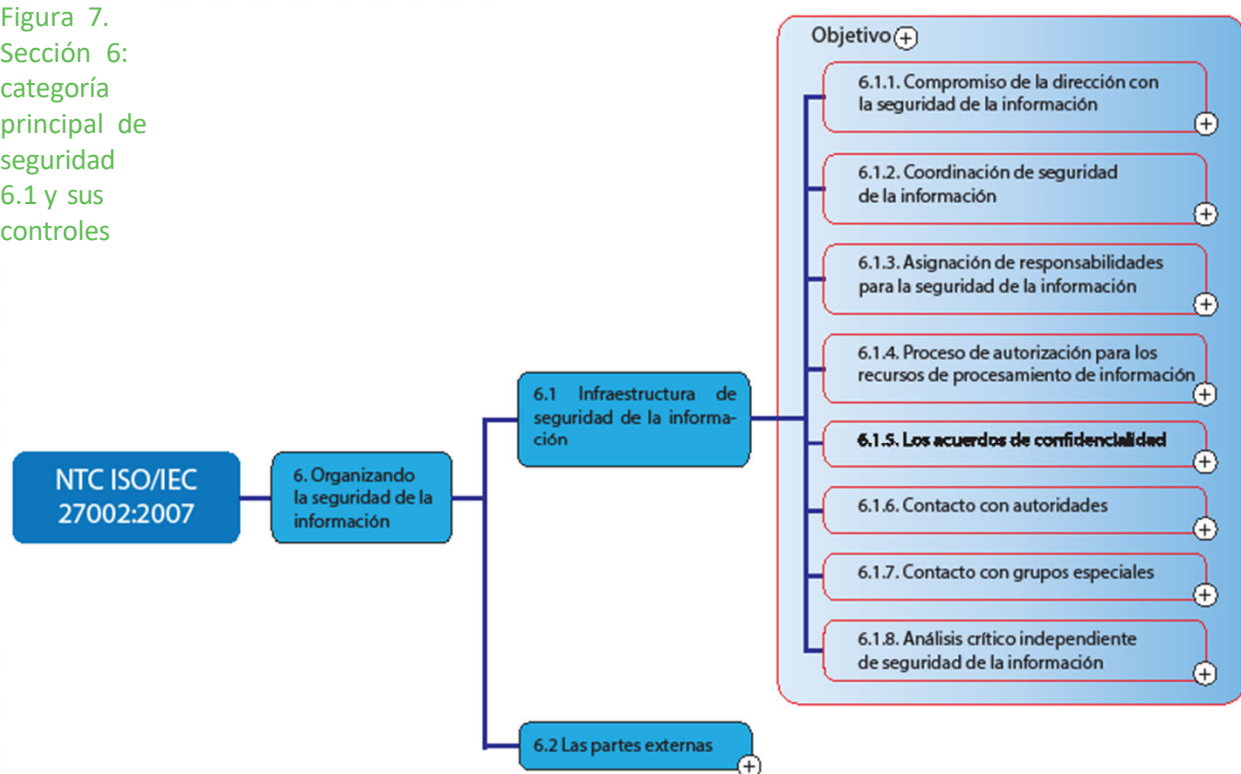
La sección 6 (organizando la seguridad de la información) tiene como objetivo presentar controles para gestionar la seguridad de la información dentro de la organización y también los controles para mantener la seguridad de los recursos de procesamiento de la información, cuando están disponibles para las partes externas. Como partes externas se entiende a todo aquel que no es parte efectiva de la estructura de la organización. Así, son ejemplos de partes externas los vendedores, proveedores, agencias gubernamentales, contratistas, proveedores de servicios temporales y los clientes, entre otros.

Figura 6.
Sección 6:
organizando
la seguridad
de la
información



En la sección 6 encontraremos los controles que deben aplicarse a la estructura funcional de la seguridad de la información. La sección 6 tiene dos categorías principales de seguridad: 6.1 (infraestructura de seguridad de la información) y 6.2 (las partes externas).

Figura 7.
Sección 6:
categoría
principal de
seguridad
6.1 y sus
controles



La categoría 6.1 (infraestructura de seguridad de la información) cuenta con ocho controles que se deben implementar. Estos controles, como puede verse en la norma, tratan de la estructura de la seguridad, sus procesos de autorización, confidencialidad, y los contactos con otros grupos.

Observe que el control 6.1.8 trata de nuevo el análisis crítico de la seguridad de la información. La seguridad de la información es parte de un proceso y debe ser analizada periódicamente, revisada y corregida para estar siempre al día con los requisitos de seguridad de la información.



Se recomendamos una lectura rápida de la categoría 6.1 de la norma ISO27002:2007.

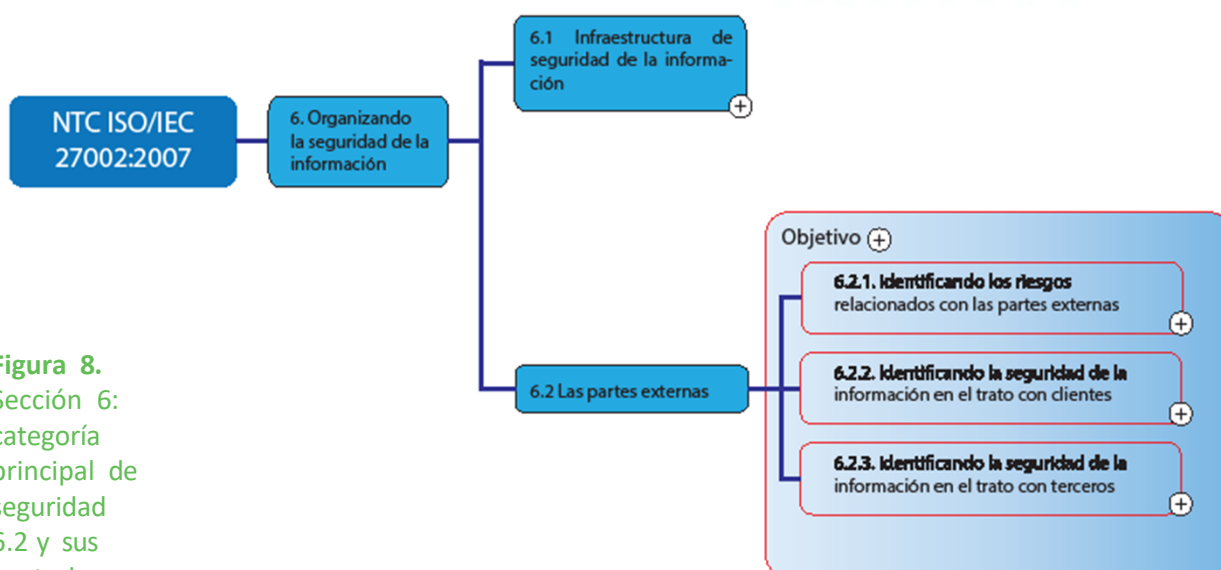


Figura 8.
Sección 6:
categoría
principal de
seguridad
6.2 y sus
controles

La categoría 6.2 (partes externas) se refiere a los controles necesarios para la relación entre la organización y las partes externas que, en algún momento y por alguna razón del negocio, necesitan tener acceso a los recursos informáticos de la organización. Es una buena práctica identificar cada una de las partes externas que existen en la relación de negocios de la organización.

Tenga en cuenta los detalles de las directrices de implementación, que relaciona lo esencial a ser cumplido en la seguridad de la información.

Ejercicio de refuerzo - sección 6: organizando la seguridad de la información

Utilizando la norma, explique los controles

- » 6.1.3
- » 6.1.5
- » 6.1.7

2.5 Sección 7: gestión de activos

En la sección 7 (gestión de activos) se presentan dos categorías principales de seguridad de la información:

- » 7.1 (Responsabilidad de los activos): representa los controles que se aplican a la protección de los activos de la organización;
- » 7.2 (Clasificación de la información): controles para la clasificación de la información, dándoles un nivel de seguridad adecuado.

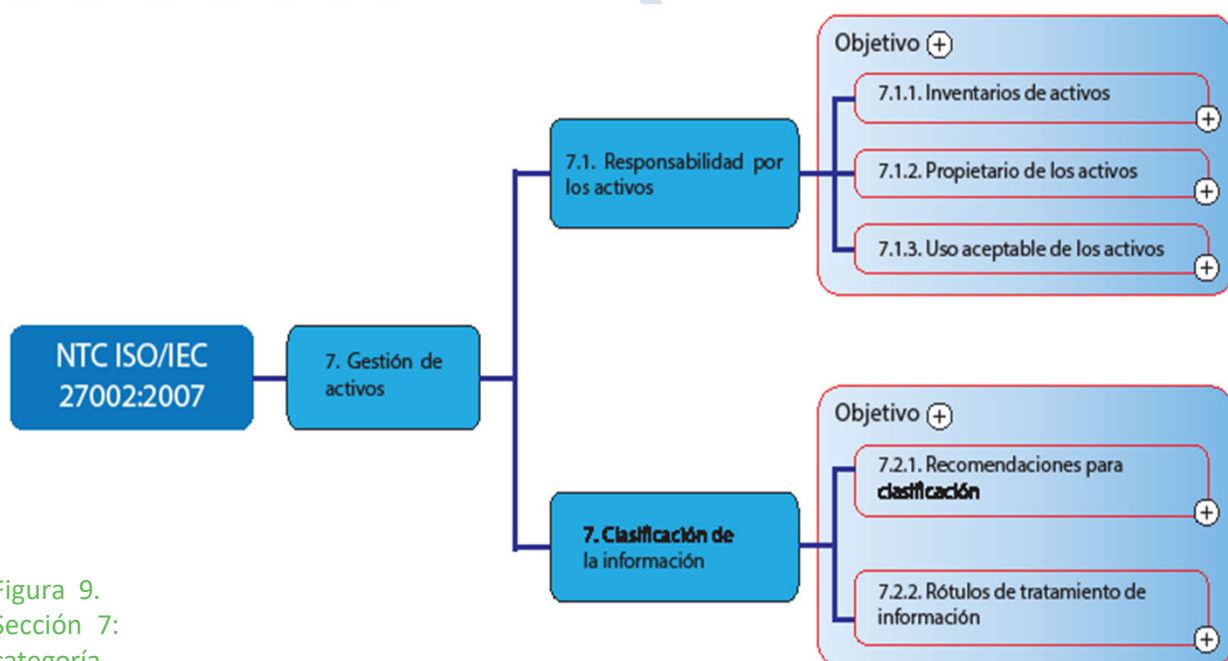


Figura 9.
Sección 7:
categoría
principal de
seguridad 7.1
y 7.2 con sus
controles

La categoría 7.1 (Responsabilidad de los activos) tiene como objetivo alcanzar y mantener la protección adecuada de los activos de la organización, presentando los controles que se deben aplicar para el tratamiento de la seguridad de la información de los activos.

El control 7.1.1 de la norma, en "información adicional", describe algunos tipos de activos. La categoría 7.2 presenta los controles para el tratamiento de la seguridad de la información que deben ser aplicados.

Ejercicio de refuerzo - sección 7: gestión de activos

Utilizando la norma, explique los controles

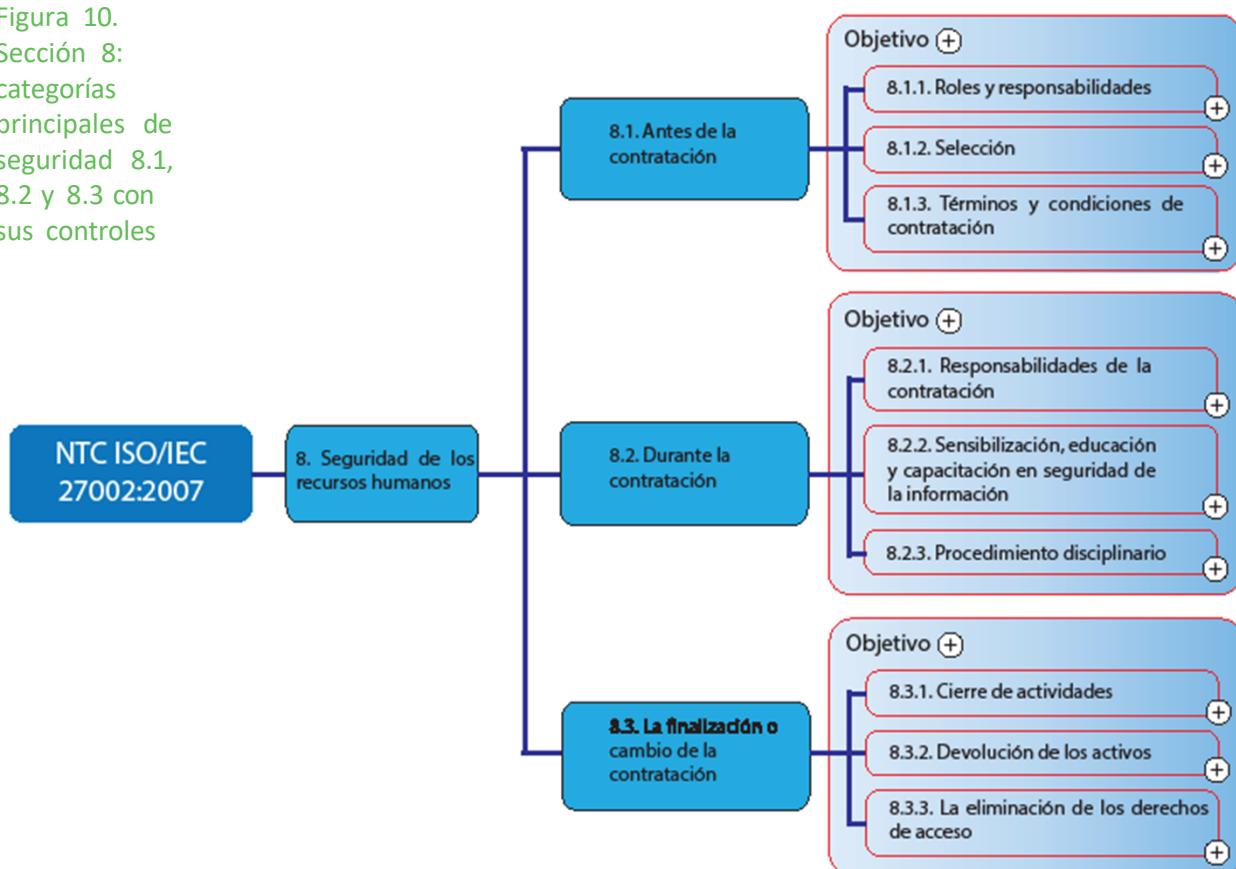
- » 7.1.1
- » 7.1.2
- » 7.2.1

2.6 Sección 8: seguridad de los recursos humanos.

La sección 8 (seguridad de los recursos humanos) se ocupa de los controles de seguridad de la información durante el ciclo de vida de la prestación de servicio de profesionales en la organización. Estos controles están dispuestos por la norma en tres categorías:

- » 8.1. Antes de la contratación;
- » 8.2. Durante la contratación;
- » 8.3. La finalización o cambio de la contratación.

Figura 10.
Sección 8:
categorías
principales de
seguridad 8.1,
8.2 y 8.3 con
sus controles



Los controles en cada categoría se organizan dentro de las necesidades mínimas de seguridad que deben observarse en cada uno de ellos.

- » Categoría 8.1 (controles responsabilidades): proceso de selección y condiciones de los contratos de recursos humanos;
- » Categoría 8.2 (controles durante la prestación de los servicios propiamente dichos): en esta categoría están los controles de responsabilidades, la capacitación de los recursos humanos en seguridad de la información y los procedimientos disciplinarios, si se produce una violación de la seguridad de la información;
- » Categoría 8.3 (controles específicos para el cierre o cambio de la contratación: cambio del área, de cargo, ascenso, etc.): en esta categoría se destacan los controles de devolución de los activos y la retirada de derechos de acceso.

Ejercicio de refuerzo - sección 8: seguridad en recursos humanos

Utilizando la norma, explique los controles

- » 8.1.1
- » 8.2.2
- » 8.3.3

2.7 Sección 9: seguridad física y del entorno

Teniendo como objetivo del tratamiento de la seguridad física y del ambiente, la sección 9 (seguridad física y del ambiente) presenta dos categorías principales de seguridad de la información:

- » 9.1. Áreas seguras;
- » 9.2. Seguridad de los equipos.

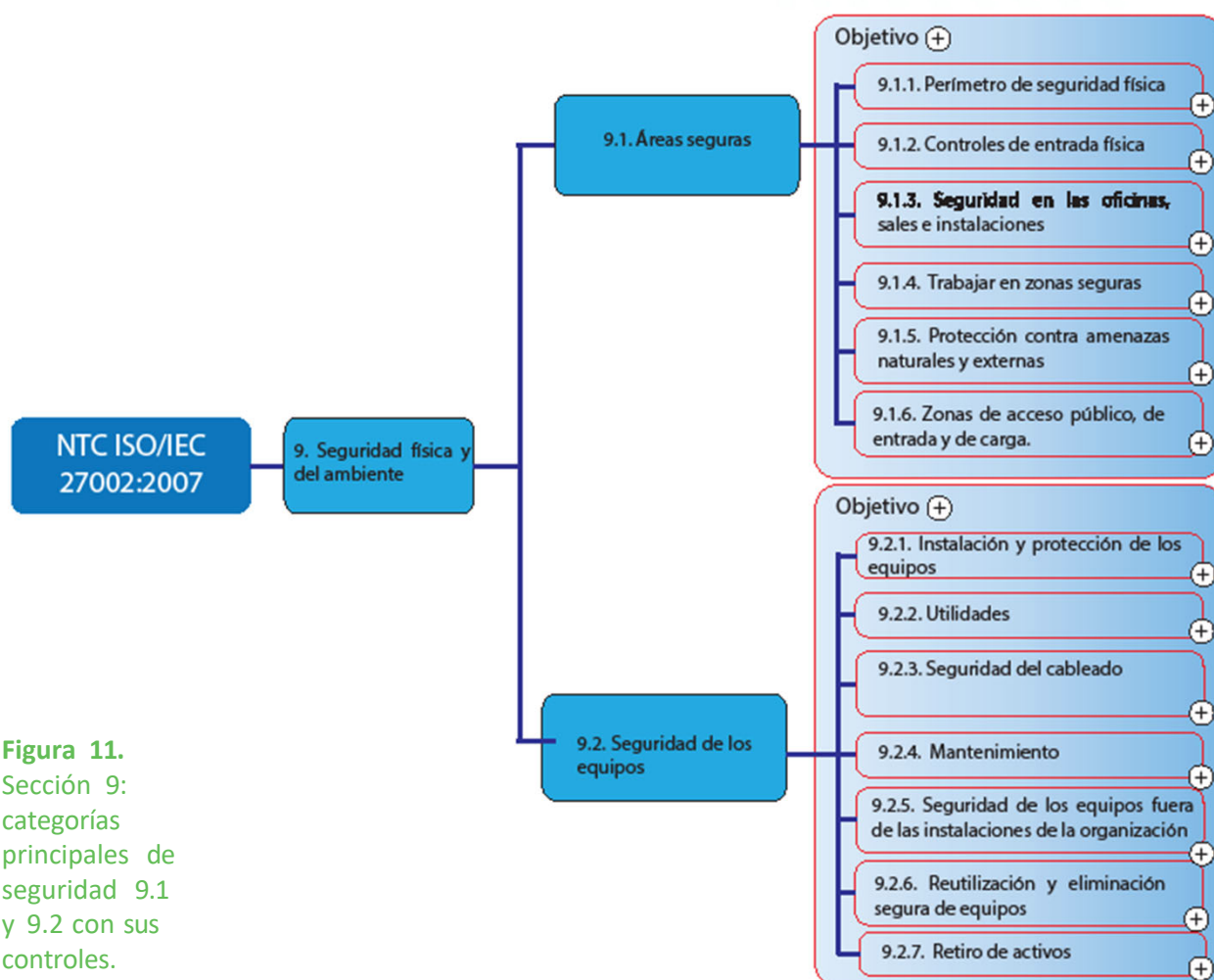


Figura 11.
Sección 9:
categorías
principales de
seguridad 9.1
y 9.2 con sus
controles.

Los controles de seguridad de la categoría 9.1 (áreas seguras) se refieren específicamente a las necesidades de seguridad de acceso físico a las instalaciones. Presenta controles de seguridad para el perímetro físico, controles de entrada a las áreas internas y externas, zonas seguras, áreas de acceso público y de entrega de materiales.

En la categoría 9.2 (seguridad de equipos) están los controles de seguridad que se refieren a la protección física de los activos y su funcionamiento sin interrupciones. Es en esta categoría donde se encuentran los controles para la instalación de equipos, suministro de energía, aire acondicionado, mantenimiento de activos, la reutilización y la venta/eliminación de los activos.

Ejercicio de refuerzo - sección 9: seguridad física y del entorno

Utilizando la norma, explique los controles

- » 9.1.2
- » 9.1.4
- » 9.2.5

2.8 Sección 10: gestión de operaciones y comunicaciones

La sección 10 (gestión de las operaciones y comunicaciones) es la sección más grande de la norma, se ocupa de las operaciones de los servicios tecnológicos de la organización. Esta sección tiene diez categorías principales de seguridad de la información, y cada uno de ellas cuenta con controles que deben ser aplicados en el día a día de las operaciones y las comunicaciones de la organización. Es la sección que muestra los controles de seguridad relacionados con la mayoría de las vulnerabilidades vinculadas a los aspectos operativos cotidianos en el área de las Tecnologías de la Información y las Comunicaciones, TICS.

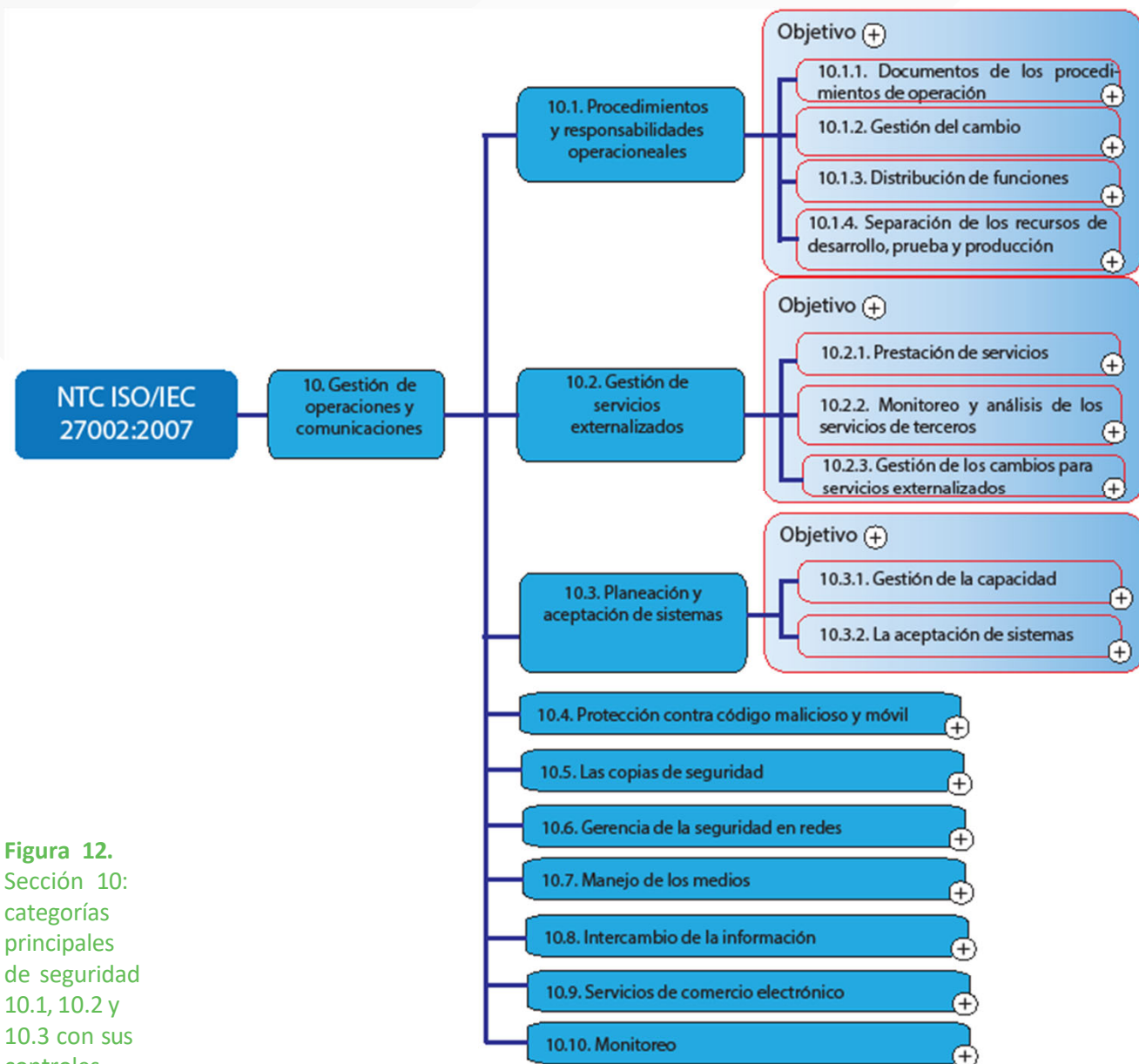


Figura 12.
Sección 10:
categorías
principales
de seguridad
10.1, 10.2 y
10.3 con sus
controles.

En la categoría 10.1 (procedimientos y responsabilidades operacionales) se muestran los controles que tienen por objeto garantizar el funcionamiento seguro y correcto de los recursos informáticos. En él se describen los controles:

- » 10.1.1 (documentos de los procedimientos de operación): se deben aplicar para documentar los procedimientos;
- » 10.1.2 (gestión del cambio): define el modo en que se deben controlar las modificaciones y alteraciones;
- » 10.1.3 (distribución de funciones): reducción de las oportunidades de uso indebido;

- » 10.1.4 (separación de recursos de desarrollo, prueba y producción): describe cómo se deben separar estos ambientes para reducir el riesgo de acceso o modificación no autorizada.

La categoría 10.2 (gestión de servicios externalizados) tiene como objetivo mantener el nivel adecuado de seguridad y de la entrega de servicios de conformidad con los acuerdos. Esta categoría incluye las siguientes medidas de control:

- » 10.2.1 (entrega de servicios): se refiere a la garantía de que los controles de seguridad acordados con terceros se cumplan en la realidad;
- » 10.2.2 (monitoreo y análisis de los servicios de terceros): aborda la necesidad de seguimiento y análisis crítico que debe hacerse periódicamente;
- » 10.2.3 (gestión del cambio para los servicios externalizados): se refiere a la necesidad de gestionar estos servicios de acuerdo al estado crítico de los sistemas y procesos.

En la categoría 10.3 (planeación y aceptación de los sistemas) el objetivo es reducir al mínimo el riesgo de fallas en los sistemas, con la presentación de los dos únicos controles:

- » 10.3.1 (gestión de capacidad): se refiere al monitoreo y la sincronización de los recursos con las proyecciones de la capacidad futura para asegurar el rendimiento requerido;
- » 10.3.2 (aceptación de sistemas): se refiere a la conveniencia de la realización de pruebas de aceptación de los nuevos sistemas y actualizaciones.

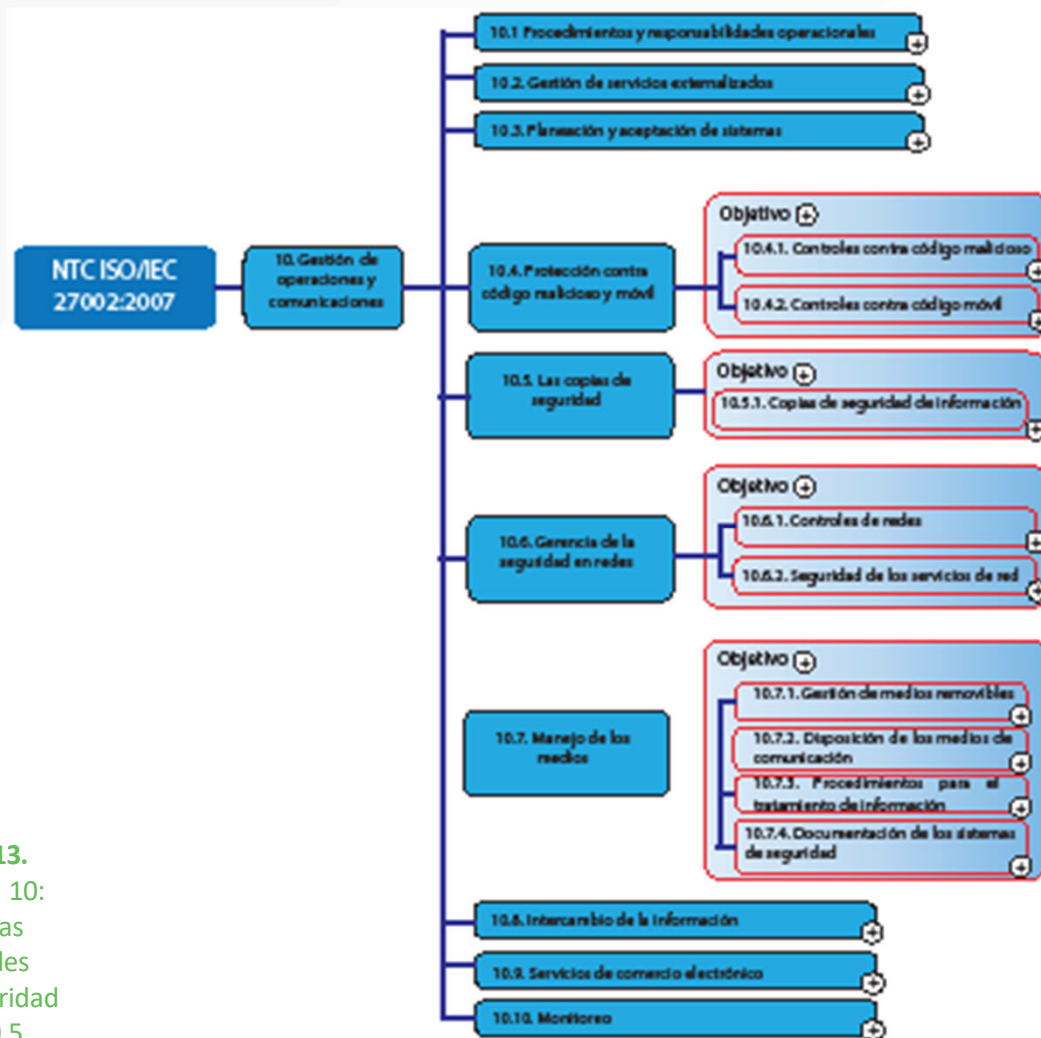


Figura 13.
Sección 10:
categorías
principales
de seguridad
10.4, 10.5,
10.6 y 10.7
con sus
controles.

La categoría 10.4 (protección contra códigos maliciosos y móviles) tiene por objeto proteger la integridad del software y la información. En esta categoría tenemos a los siguientes controles:

- » 10.4.1 (controles contra código malicioso): que describe los procedimientos para la implementación de controles para la detección, prevención y recuperación para protegerse contra código malicioso;
- » 10.4.2 (controles contra códigos móviles): muestra las directrices para el uso de código móvil de forma segura.

En la categoría 10.5 (copias de seguridad de información), el objetivo es mantener la integridad y disponibilidad de la información a través del siguiente control:

- » 10.5.1 se refiere a la necesidad de que copias de seguridad (*backup*) de la información y de los programas de software sean efectuadas y probadas regularmente.

La categoría 10.6 (gestión de seguridad de la red) tiene por objeto garantizar la protección de la información en las redes y la protección de la infraestructura de soporte. Esta categoría tiene dos controles:

- » 10.6.1 (control de redes): se refiere a la necesidad de una adecuada gestión y control de las redes, incluida la información en tránsito;
- » 10.6.2 (seguridad de los servicios de red): describe la necesidad de que los niveles de los servicios de red sean identificados e incluidos en los acuerdos de nivel de servicio.

En la categoría 10.7 (manipulación de medios) se describen los controles que deben ser aplicados para evitar la divulgación no autorizada, modificación, supresión o destrucción. Son los siguientes controles:

- » 10.7.1 (gestión de medios removibles): describe la necesidad de controles para la gestión de medios removibles;
- » 10.7.2 (eliminación de medios): muestra cómo se debe realizar la eliminación de los medios;
- » 10.7.3 (procedimientos para el manejo de la información): presenta los controles que deben ser aplicados para el manejo y almacenamiento de la información, evitando la divulgación no autorizada;
- » 10.7.4 (seguridad de la documentación del sistema): presenta el control de protección de la documentación del sistema.

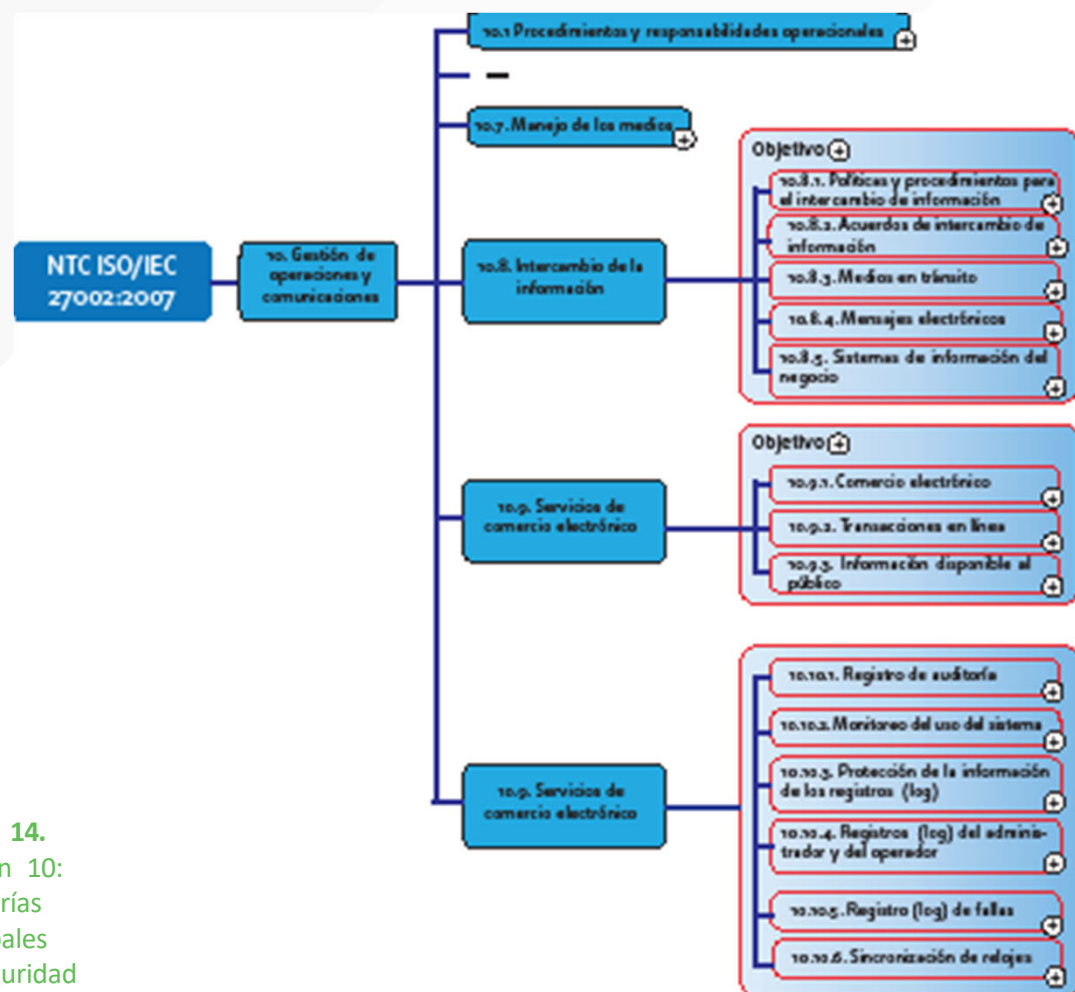


Figura 14.
Sección 10:
categorías
principales
de seguridad
10.8, 10.9, y
10.10 con sus
controles.

La categoría 10.8 (intercambio de información) tiene como objetivo mantener la seguridad en el intercambio de la información interna y con entidades externas. Posee los siguientes controles:

- » 10.8.1 (políticas y procedimientos para el intercambio de información): es conveniente que sean establecidas políticas y procedimientos para proteger el intercambio de información;
- » 10.8.2 (acuerdos de intercambio de información): se deben establecer acuerdos para el intercambio de información;
- » 10.8.3 (medios en tránsito): es recomendable que el transporte de los medios se haga bajo protección contra el uso indebido o el acceso no autorizado de esos dichos medios;

- » 10.8.4 (mensajes electrónicos): es conveniente que los mensajes estén protegidos adecuadamente;
- » 10.8.5 (sistema de información del negocio): se recomienda que las políticas y procedimientos estén diseñados para proteger la información en las interconexiones del sistema.

En la categoría 10.9 (servicios de comercio electrónico), el objetivo es garantizar la seguridad durante el uso de los servicios de comercio electrónico y su uso seguro. En esta categoría se encuentran los controles:

- » 10.9.1 (comercio electrónico): se refiere a la protección de la información involucrada en el comercio electrónico contra las actividades fraudulentas;
- » 10.9.2 (transacciones en línea): conviene realizar la protección de información para prevenir la transmisión incompleta, entre otros;
- » 10.9.3 (información disponible al público): es recomendable asegurar la integridad de la información proporcionada en los sistemas públicos.

La categoría 10.10 (monitoreo) tiene como objetivo detectar las actividades no autorizadas de procesamiento de información. Los controles son:

- » 10.10.1 (registros de auditoría): es importante que todos los *log* de auditoría de eventos de seguridad se generen y se conserven durante un período de tiempo acordado;
- » 10.10.2 (monitoreo del uso del sistema): se deben establecer procedimientos para supervisar el uso de los recursos de procesamiento de la información;
- » 10.10.3 (protección de la información de los registros (*log*)): los logs deben estar protegidos contra cambios no autorizados y problemas operacionales;
- » 10.10.4 (registros (*log*) de administrador y operador): se recomienda registrar las actividades de los administradores y operadores del sistema;
- » 10.10.5 (registros (*logs*) de las fallas): es conveniente que las fallas sean registradas y analizadas;
- » 10.10.6 (sincronización de relojes): todos los sistemas relevantes deben tener sus relojes sincronizados.

Ejercicio de refuerzo - sección 10: gestión de operaciones y comunicaciones

Utilizando la norma, explique los controles

- » 10.1.3
- » 10.2.2
- » 10.4.1
- » 10.5.1
- » 10.6.2
- » 10.7.1
- » 10.10.2

2.9 Sección 11: control de acceso

En la sección 11 (control de acceso) se encuentran las categorías que abordan los controles necesarios a los controles de acceso lógico. A diferencia de la sección 9 (seguridad física y del ambiente), en la sección 11 se abordarán aspectos relacionados con los privilegios de acceso, contraseñas, acceso a la red, entre otros. En esta sección hay siete principales categorías de seguridad.

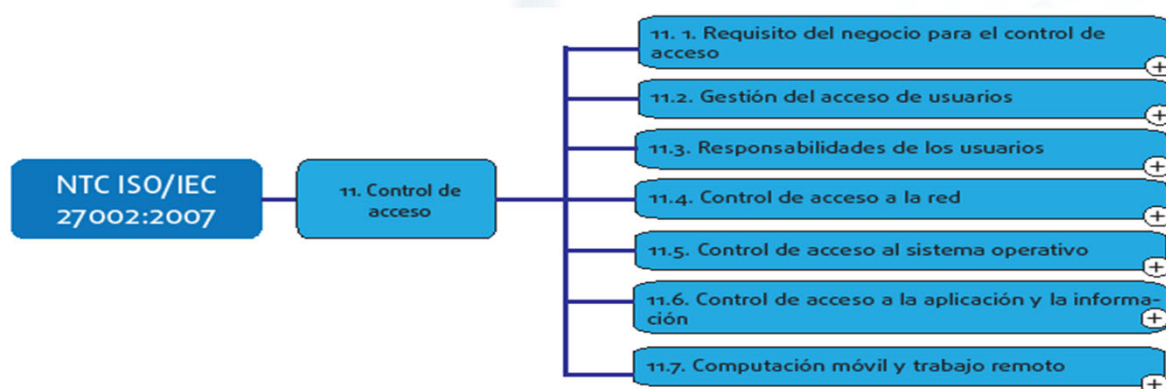


Figura 15.
Sección 11
y sus siete
categorías
principales
de seguridad

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.1 (requisitos de negocio para el control de acceso), categoría 11.2 (gestión de acceso de usuario) y categoría 11.3 (responsabilidades de los usuarios).

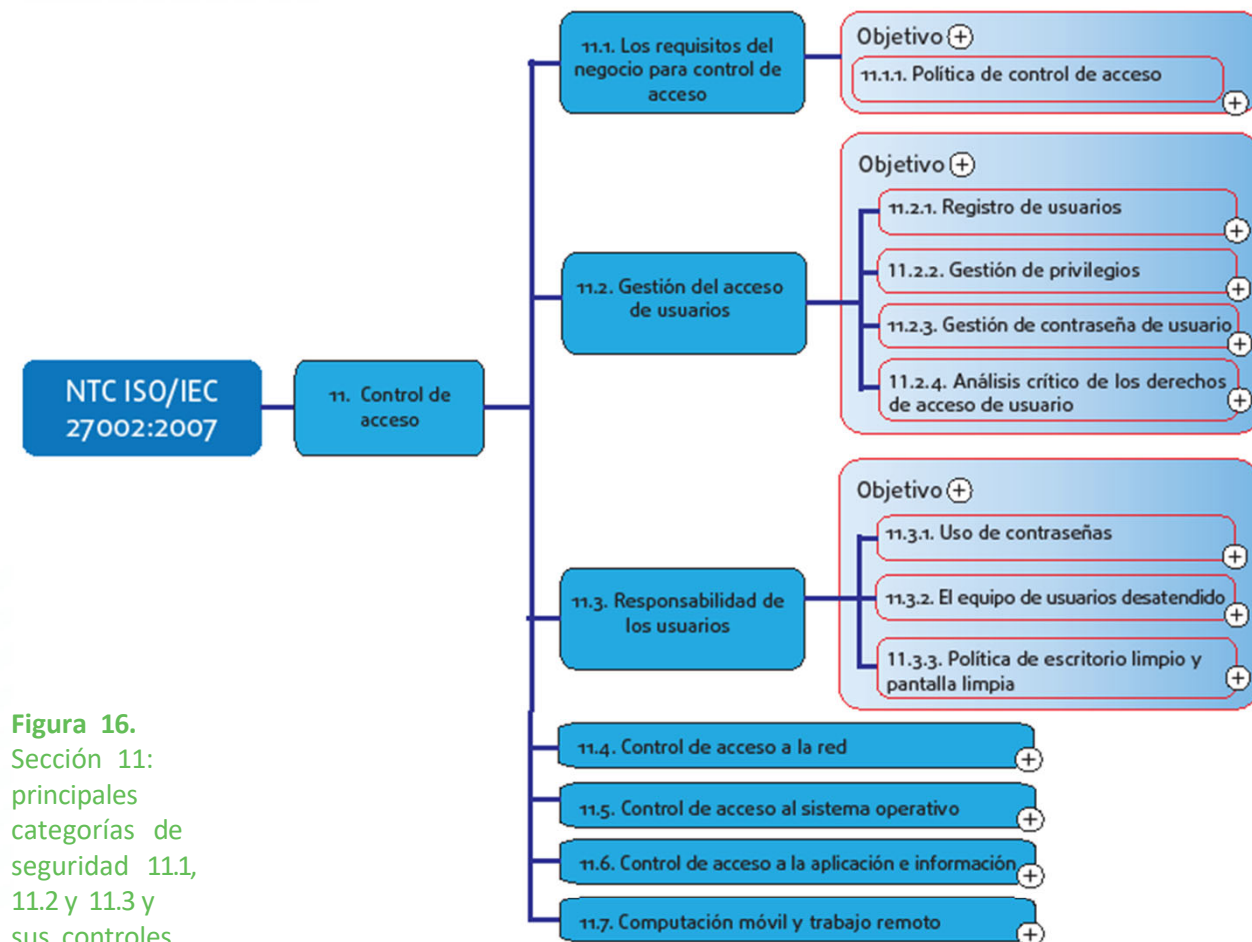


Figura 16.
Sección 11:
principales
categorías de
seguridad 11.1,
11.2 y 11.3 y
sus controles.

En la categoría 11.1 (requisitos de negocio para el control de acceso) el objetivo es controlar el acceso a la información. El control es:

- » 11.1.1 (política de control de acceso): debe haber una política de control de acceso establecida y analizada críticamente.

La categoría 11.2 (gestión de acceso de usuario): tiene como objetivo garantizar el acceso a los usuarios autorizados y evitar el acceso no autorizado. Los controles son:

- » 11.2.1 (registro de usuario): describe la conveniencia de la existencia de un procedimiento formal de registro y cancelación de usuarios;
- » 11.2.2 (gestión de privilegios): muestra la necesidad de que la concesión y uso de privilegios deben ser restringidos y controlados;
- » 11.2.3 (gestión de contraseña): tiene la ventaja de que la concesión de las contraseñas sea controlada;
- » 11.2.4 (análisis crítico de los derechos de acceso de usuario): presenta la conveniencia de que el administrador realice análisis críticos periódicos sobre los derechos de acceso de los usuarios.

La categoría 11.3 (responsabilidades de los usuarios) tiene por objeto prevenir el acceso no autorizado y evitar la afectación o el robo de los recursos. Contamos con los controles:

- » 11.3.1 (uso de contraseñas): aborda la necesidad de los usuarios a seguir las mejores prácticas en el uso y la selección de las contraseñas;
- » 11.3.2 (equipo del usuario desatendido): muestra la importancia de que los equipos desatendidos tengan la protección adecuada;
- » 11.3.3 (política de escritorio limpio y pantalla limpia): muestra la conveniencia de adoptar una política de mesa limpia de papeles y de medios, y también de pantalla limpia.

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.4 (control de acceso a redes) y categoría 11.5 (control de acceso al sistema operativo).

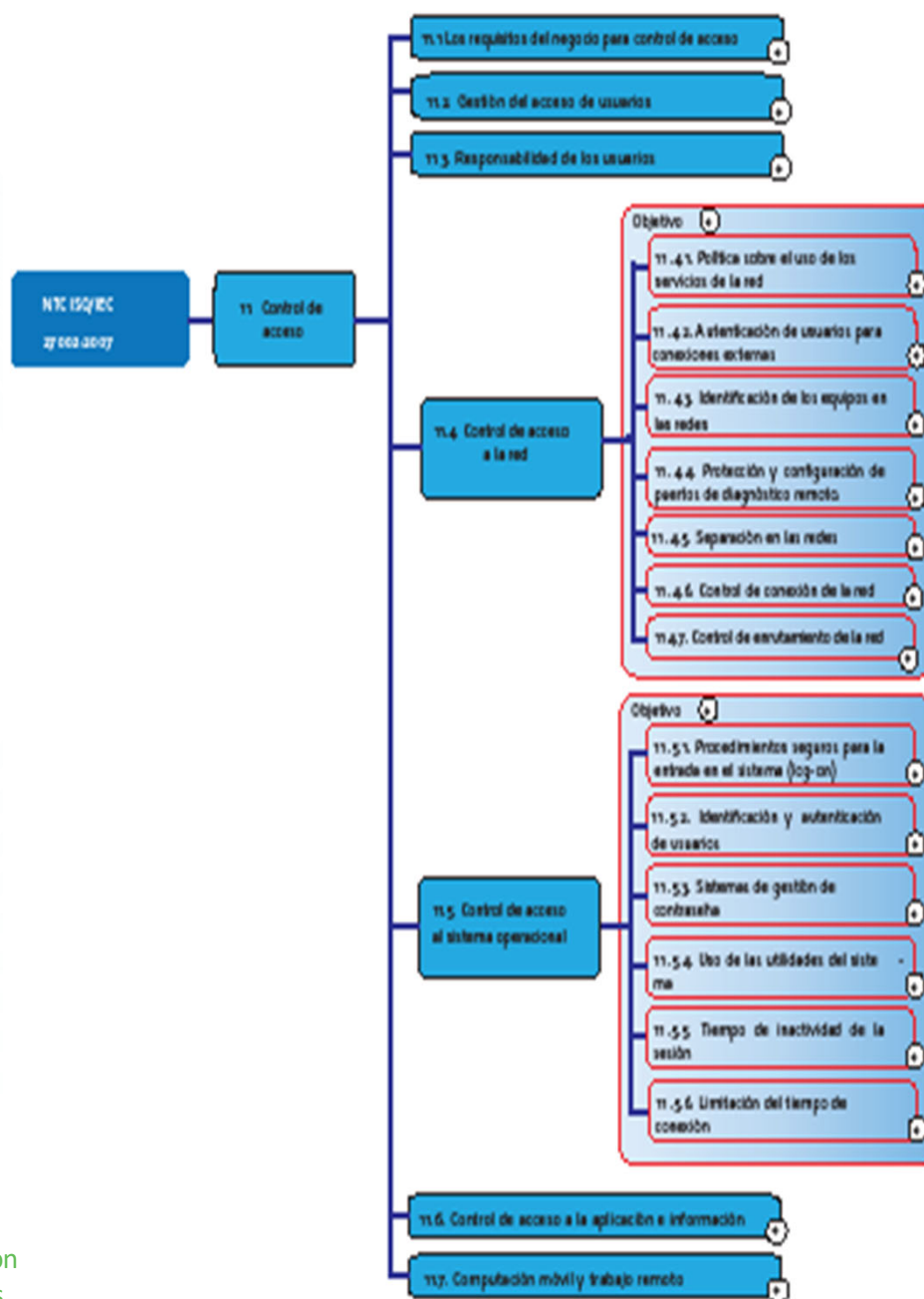


Figura 17.
Sección 11:
categorías
principales
de seguridad
11.4 y 11.5 con
sus controles

La categoría 11.4 (control de acceso a redes) tiene por objeto prevenir el acceso no autorizado a los servicios de red. Tiene los siguientes controles:

- » 11.4.1 (política de uso de los servicios de red): presenta la conveniencia de que los usuarios reciban acceso sólo a los servicios que hayan sido autorizados a usar;
- » 11.4.2 (autenticación de usuarios para conexiones externas): recomienda que se usen métodos adecuados para controlar el acceso de usuarios remotos;

- » 11.4.3 (identificación de los equipos en las redes): recomienda la conveniencia de permitir la identificación automática de los equipos;
- » 11.4.4 (protección y configuración de puertos de diagnóstico remoto): recomienda que se controle el acceso físico y lógico a los puertos de diagnóstico y configuración;
- » 11.4.5 (separación en las redes): recomienda que los usuarios y los sistemas sean separados en las redes;
- » 11.4.6 (control de conexión de red): recomienda que la capacidad de los usuarios para conectarse a la red esté restringida,
- » 11.4.7 (control de enrutamiento de la red): presenta la recomendación de que se implemente un control de enrutamiento de red para que las conexiones de red y los flujos de información no violen la política de control de acceso.

La categoría 11.5 (control de acceso al sistema operativo) tiene por objeto prevenir el acceso no autorizado a los sistemas operativos. Los controles son:

- » 11.5.1 [Los procedimientos seguros para la entrada al sistema (*log-on*)]: muestra la conveniencia de que el acceso sea controlado por un procedimiento seguro para la entrada en el sistema;
- » 11.5.2 (identificación y autenticación de usuarios): presenta la conveniencia de que todos los usuarios tengan un identificador único, con una técnica adecuada para la validación de la identidad del usuario;
- » 11.5.3 (sistema de gestión de contraseñas): recomienda que los sistemas para la gestión de las contraseñas sean interactivos;
- » 11.5.4 (uso de las utilidades del sistema): recomienda que el uso de las utilidades del sistema sea restringido y controlado;
- » 11.5.5 (tiempo de inactividad de la sesión): muestra la necesidad de suspender las sesiones inactivas;
- » 11.5.6 (limitación del tiempo de conexión): presenta la posibilidad de realizar restricciones en los tiempos de conexión.

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 11.6 (control de acceso a las aplicaciones y la información) y categoría 11.7 (computación móvil y trabajo remoto).

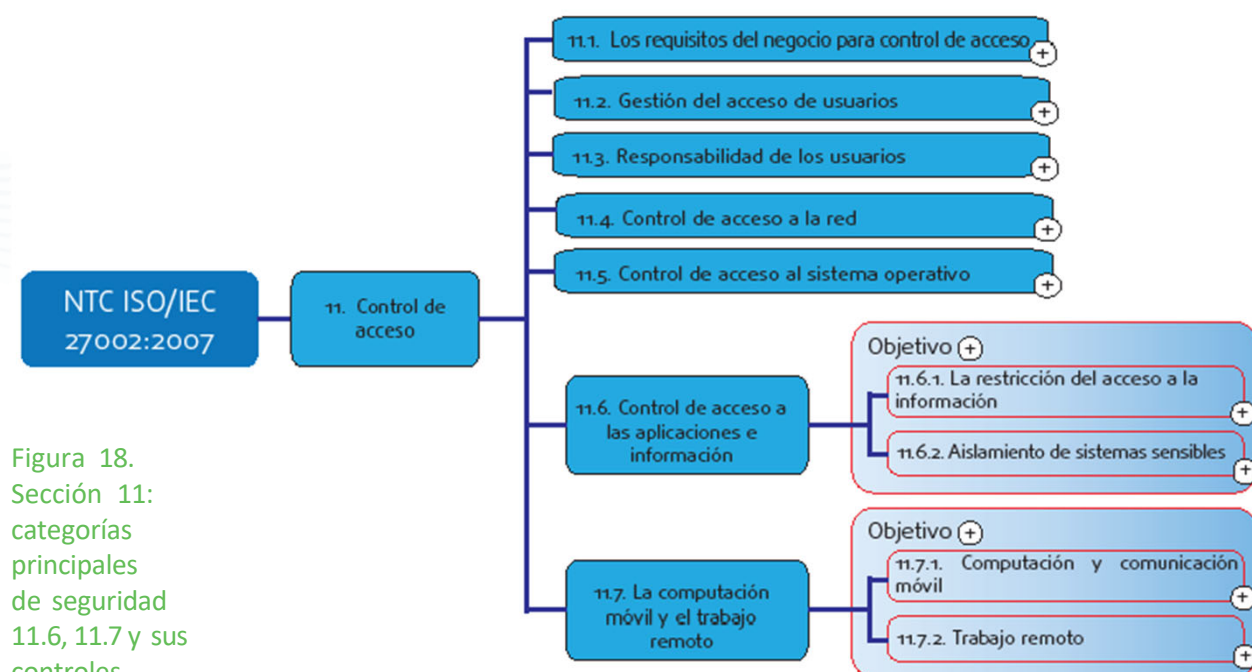


Figura 18.
Sección 11:
categorías
principales
de seguridad
11.6, 11.7 y sus
controles.

En la categoría 11.6 (control de acceso a las aplicaciones y a la información), el objetivo es prevenir el acceso no autorizado a la información contenida en los sistemas de aplicación. Los controles son:

- » 11.6.1 (restricción de acceso a la información): establece que el acceso a la información y las funciones de los sistemas de aplicación de los usuarios y personal de soporte sean restringidos;
- » 11.6.2 (aislamiento de sistemas sensibles): recomienda que los sistemas sensibles tengan un ambiente informático aislado.

La categoría 11.7 (computación móvil y trabajo remoto) tiene como objetivo garantizar la seguridad de la información cuando se utilizan la computación móvil y el trabajo remoto. Los controles son:

- » 11.7.1 (computación y comunicación móvil): recomienda la adopción de políticas y medidas contra los riesgos debidos al uso de los recursos informáticos y de comunicaciones móviles;
- » 11.7.2 (trabajo remoto): presenta las ventajas de que las políticas, planes y procedimientos sean elaborados e implementados para el trabajo remoto.

Ejercicio de refuerzo - sección 11: control de acceso

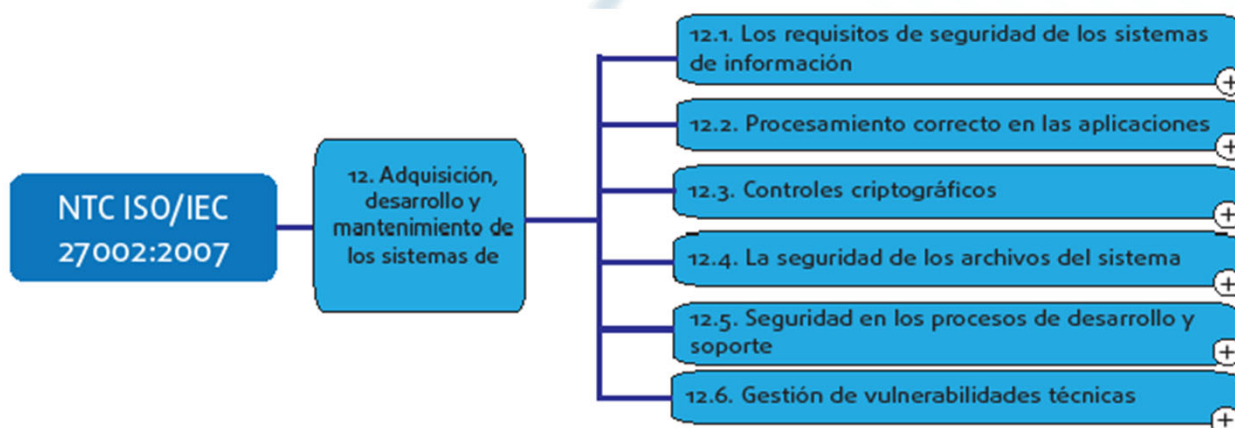
Utilizando la norma, explique los controles

- » 11.1.1
- » 11.2.2
- » 11.3.3
- » 11.5.5
- » 11.6.2

2.10 Sección 12: adquisición, desarrollo y mantenimiento de sistemas de información.

En la sección 12 (adquisición, desarrollo y mantenimiento de sistemas de información) están los controles sobre la adquisición, desarrollo y mantenimiento de las actividades de software. El objetivo de esta sección es desarrollar la seguridad de la información en las aplicaciones de la organización. Esta sección tiene seis categorías principales de seguridad.

Figura 19.
Sección 12
y sus seis
categorías
principales
de seguridad



En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 12.1 (requisitos de seguridad de sistemas de información), categoría 12.2 (procesamiento correcto en las aplicaciones) y categoría 12.3 (controles criptográficos).

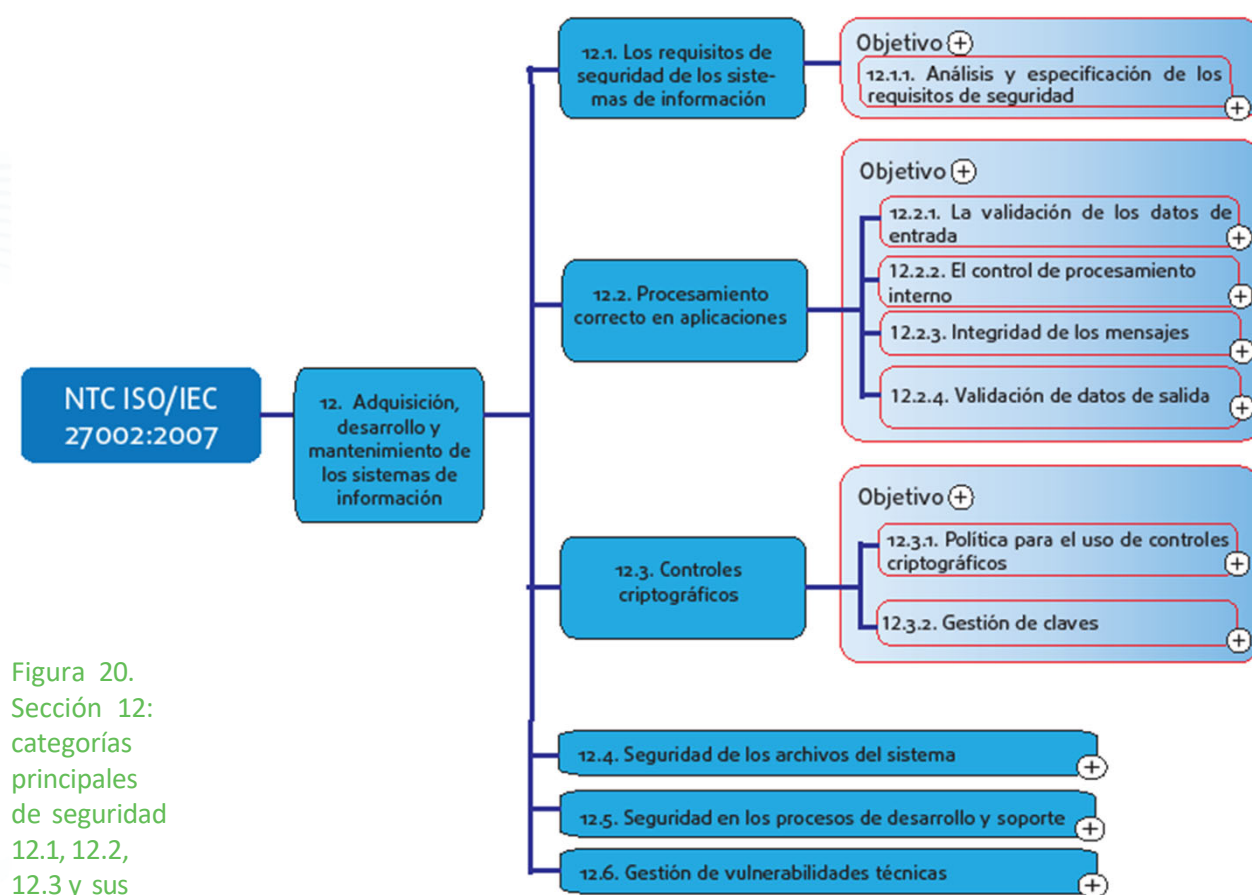


Figura 20.
Sección 12:
categorías
principales
de seguridad
12.1, 12.2,
12.3 y sus
controles.

La categoría 12.1 (requisitos de seguridad de sistemas de información) tiene por objeto garantizar que la seguridad es una parte integrante de los sistemas de información. Tiene el siguiente control:

- » 12.1.1 (análisis y especificación de requisitos de seguridad): define los controles de seguridad en las especificaciones de requisitos para los nuevos sistemas.

En la categoría 12.2 (procesamiento correcto en las aplicaciones) el objetivo es prevenir la ocurrencia de errores, pérdida, modificación no autorizada o mal uso de la información en las aplicaciones. Los controles son:

- » 12.2.1 (validación de datos de entrada): establece que los datos de entrada a las aplicaciones sean validados para asegurar que son correctos y adecuados;
- » 12.2.2 (control de procesamiento interno): se recomienda comprobar que la validación se incorpora en las aplicaciones para detectar corrupción de datos;

- » 12.2.3 (integridad de mensajes): establece que se implementen requisitos para garantizar la autenticidad y proteger la integridad;
- » 12.2.4 (Validación de datos de salida): se recomienda que los datos de salida sean validados para garantizar que el procesamiento es correcto.

La categoría 12.3 (controles criptográficos) tiene por objeto proteger la confidencialidad, autenticidad o integridad de la información por medios criptográficos. Los controles son:

- » 12.3.1 (política sobre el uso de controles criptográficos): en ella se recomienda que se desarrolle e implemente una política para el uso de controles criptográficos.
- » 12.3.2 (gestión de claves): presenta las ventajas de que un proceso de gestión de claves sea implantado para apoyar el uso de técnicas criptográficas

En la siguiente figura se establecen las principales categorías de seguridad y sus respectivos controles: categoría 12.4 (seguridad de los archivos del sistema), categoría 12.5 (seguridad en los procesos de desarrollo y soporte) y categoría 12.6 (gestión de las vulnerabilidades técnicas).

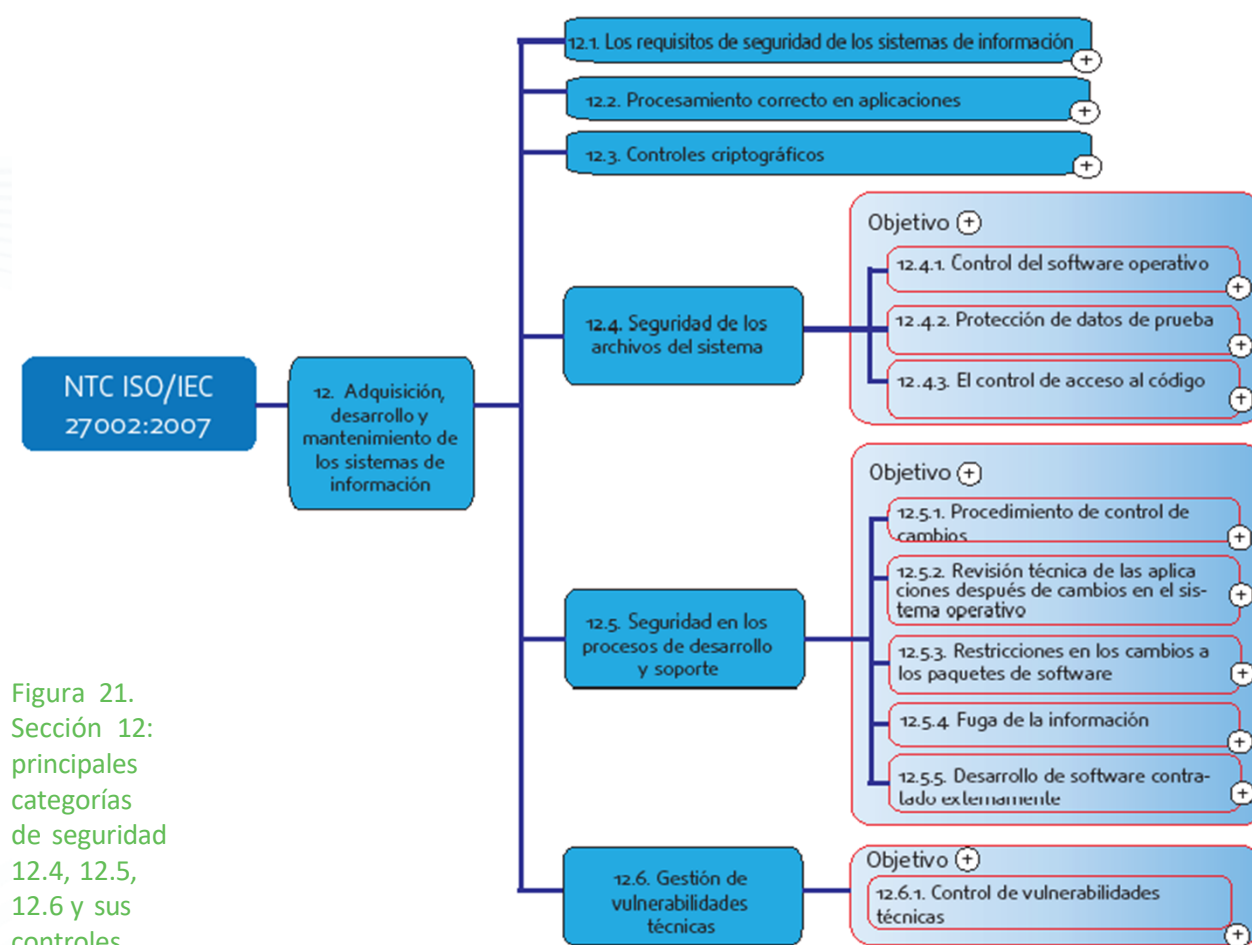


Figura 21.
Sección 12:
principales
categorías
de seguridad
12.4, 12.5,
12.6 y sus
controles.

La categoría 12.4 (seguridad de los archivos del sistema) tiene por objeto garantizar la seguridad de los archivos del sistema. Los controles son:

- » 12.4.1 (control de software operativo): se deben implementar procedimientos para el control de la instalación de software en los sistemas operativos;
- » 12.4.2 (protección de datos para la prueba del sistema): presenta la recomendación de que los datos de prueba sean seleccionados con cuidado, protegidos y controlados,
- » 12.4.3 (controlar el acceso al código fuente del programa): especifica que el acceso al código fuente sea restringido.

La categoría 12.5 (seguridad en los procesos de desarrollo y soporte) tiene como objetivo mantener la seguridad de los sistemas de información y aplicaciones. Posee los controles:

- » 12.5.1 (procedimientos de control de cambios): es conveniente que la implementación de cambios sea controlada con el uso de procedimientos formales de control de cambios;

- » 12.5.2 (revisión técnica de las aplicaciones después de los cambios del sistema operativo): considera conveniente que las aplicaciones críticas sean analizadas y probadas cuando se cambian los sistemas operativos;
- » 12.5.3 (restricciones a los cambios en los paquetes de software): presenta la recomendación de que todos los cambios sean estrictamente controlados;
- » 12.5.4 (fuga de información): resalta la necesidad de evitar toda oportunidad de fuga de información;
- » 12.5.5 (desarrollo de software contratado externamente): la organización debe supervisar y monitorear el desarrollo de software contratado externamente.

En la categoría 12.6 (gestión de las vulnerabilidades técnicas) el objetivo es reducir los riesgos derivados de la explotación de las vulnerabilidades técnicas conocidas. El control es:

- » 12.6.1 (control de las vulnerabilidades técnicas): es conveniente obtener información sobre las vulnerabilidades técnicas, los riesgos deben ser evaluados y se deben tomar los cuidados necesarios.

Ejercicio de refuerzo - sección 12: adquisición, desarrollo y mantenimiento de sistemas de información.

Utilizando la norma, explique los controles

- » 12.1.1
- » 12.2.2
- » 12.3.1
- » 12.5.4
- » 12.6.1

2.11 Sección 13: gestión de incidentes de seguridad de la información.

Sección 13 (gestión de incidentes de seguridad de la información) se refiere al reporte de eventos de seguridad, las responsabilidades y el proceso de recolección de evidencia. Tiene dos categorías de seguridad principales.

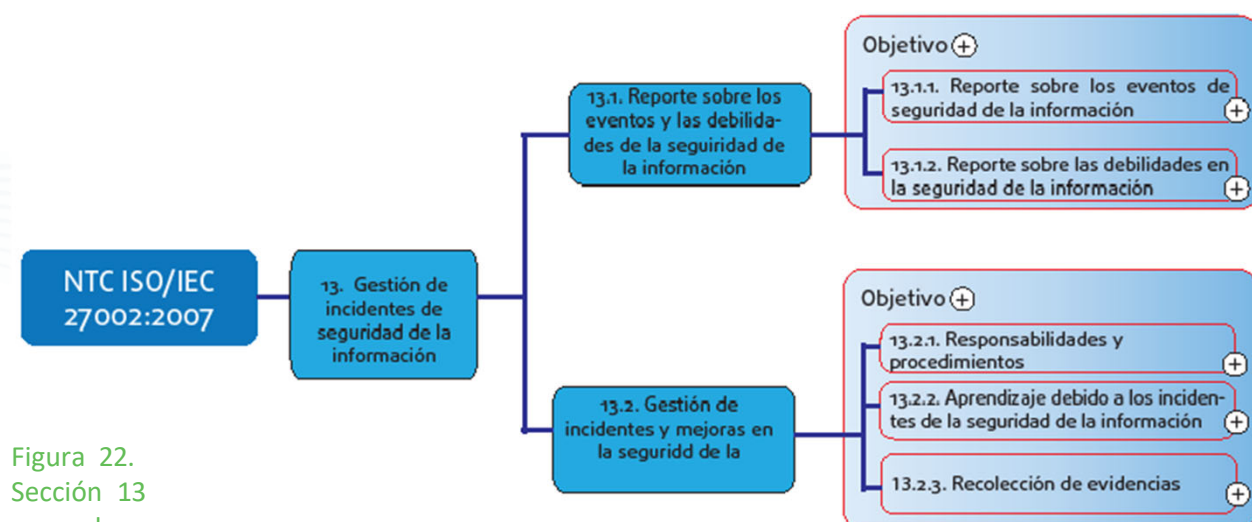


Figura 22.
Sección 13
y sus dos
principales
categorías de
seguridad y
los controles

La categoría 13.1 (reportes sobre los eventos y las debilidades de la seguridad de la información) tiene como objetivo asegurar que los eventos y las debilidades de la seguridad sean comunicados, permitiendo tomar medidas correctivas en tiempo real. Tiene los controles:

- » 13.1.1 (reporte sobre los eventos de seguridad de la información): define que los eventos de seguridad sean informados a través de los canales apropiados tan pronto como sea posible,
- » 13.1.2 (reporte sobre las debilidades en la seguridad de la información): se recomienda que todos los recursos humanos sean instruidos para registrar y reportar cualquier observación o sospecha de deficiencia de los sistemas y servicios.

La categoría 13.2 (gestión de incidentes y mejoras en la seguridad de la información) tiene por objeto garantizar que un enfoque coherente y eficaz sea aplicado a la gestión de incidentes de seguridad de la información. Los controles son:

- » 13.2.1 (responsabilidades y procedimientos): presenta la conveniencia de que las responsabilidades y los procedimientos se establezcan para garantizar una respuesta rápida;
- » 13.2.2 (aprendizaje debido a los incidentes de seguridad de la información): recomienda que se establezcan mecanismos para monitorear y cuantificar los tipos y costos de los incidentes;

- » 13.2.3 (recolección de evidencia): presenta la necesidad de recolectar la evidencia, almacenarla y se presentarla de conformidad con la legislación pertinente.

Ejercicio de refuerzo - sección 13: gestión de incidentes de seguridad de la información.

Utilizando la norma, explique los controles

- » 13.1.1
- » 13.1.2
- » 13.2

2.12 Sección 14: gestión de la continuidad del negocio.

La sección 14 (gestión de la continuidad del negocio) se encarga de todos los aspectos de la continuidad en el caso de un desastre. Esta sección tiene una sola categoría principal de seguridad.

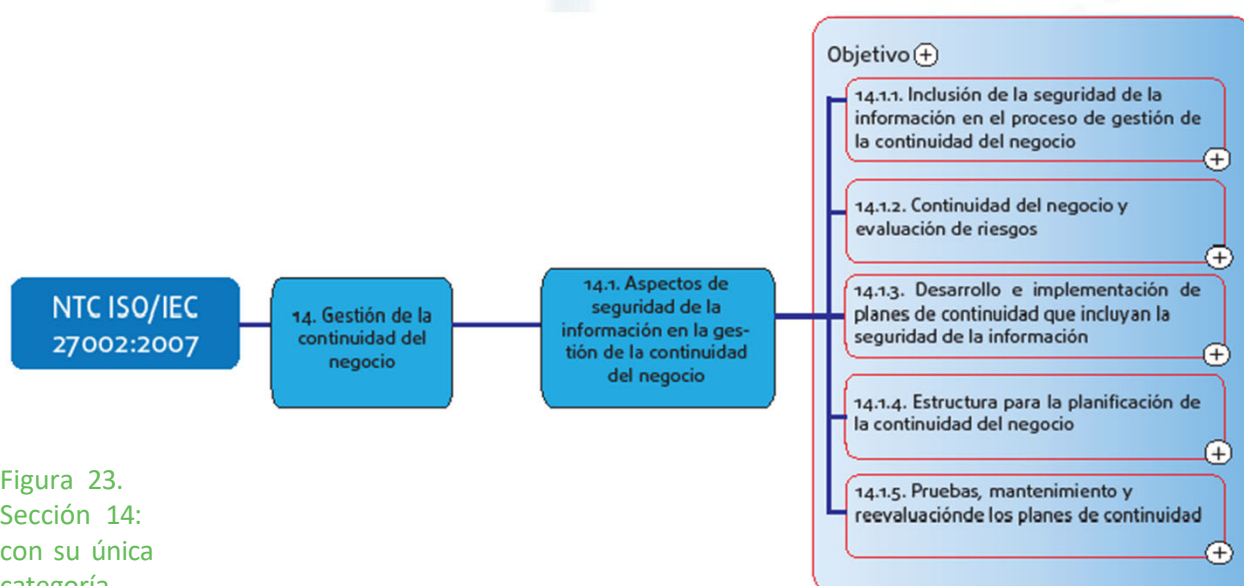


Figura 23.
Sección 14:
con su única
categoría
principal de la
seguridad y
sus controles

La categoría 14.1 (aspectos de seguridad de la información en la gestión de la continuidad del negocio) tiene como objetivo no permitir la interrupción de las actividades del negocio y proteger los procesos críticos contra los efectos de fallas o desastres significativos, y asegurar su reactivación de manera oportuna, si es el caso. Los controles son:

- » 14.1.1 (inclusión de la seguridad de la información en el proceso de gestión de la continuidad del negocio): es conveniente que sea desarrollado y mantenido un proceso de gestión de continuidad de negocio de la organización, contemplando los requisitos de seguridad;
- » 14.1.2 (continuidad del negocio y evaluación de riesgos): se deben identificar los eventos que pueden causar la interrupción del negocio;
- » 14.1.3 (desarrollo e implementación de planes de continuidad que incluyan la seguridad de la información): es importante que los planes se elaboren y se implementen;
- » 14.1.4 (estructura para la planificación para la continuidad del negocio): presenta la necesidad de una estructura básica y consistente de los planes de continuidad del negocio;
- » 14.1.5 (pruebas, mantenimiento y reevaluación de los planes de continuidad del negocio): los planes deben ser probados y actualizados con regularidad.

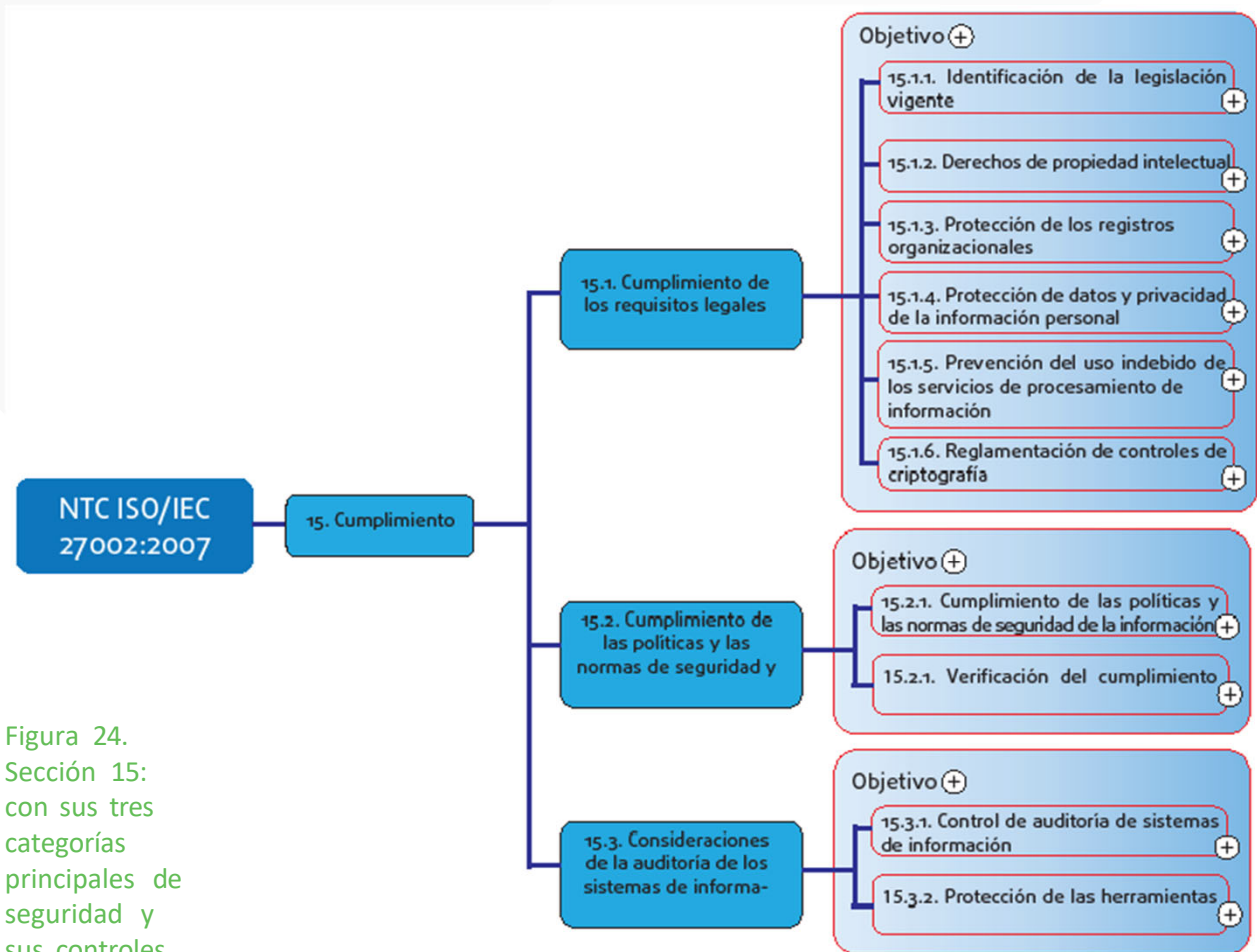
Ejercicio de refuerzo - sección 14: gestión de la continuidad del negocio

Utilizando la norma, explique los controles

- » 14.1.2
- » 14.1.3

2.13 Sección 15: cumplimiento

La sección 15 (cumplimiento) establece que los requisitos de seguridad de la información estén de acuerdo con cualquier Ley (legalidad), como reglamentos, estatutos u obligaciones contractuales. Esta sección tiene tres categorías principales de seguridad.



La categoría 15.1 (cumplimiento de los requisitos legales) tiene como objetivo prevenir la violación de cualquier Ley penal o civil, estatutos, reglamentaciones u obligaciones contractuales y cualquier otro requisito de seguridad de la información. Cuenta con los siguientes controles:

- » 15.1.1 (identificación de la legislación vigente): considera conveniente que todos los requisitos legales y contractuales se definan explícitamente, y sean documentados y mantenidos;
- » 15.1.2 (derechos de propiedad intelectual): recomienda que se implementen procedimientos para garantizar el cumplimiento de los derechos de propiedad intelectual;
- » 15.1.3 (protección de los registros organizacionales): recomienda que los registros sean protegidos contra pérdida, destrucción y falsificación;
- » 15.1.4 (protección de datos y privacidad de la información personal): indica que la privacidad y la protección de datos sean garantizadas;
- » 15.1.5 (prevención del uso indebido de los servicios de procesa-

miento de información): se recomienda que los usuarios sean disuadidos de usar los servicios informáticos para propósitos no autorizados,

- » 15.1.6 (Reglamento de controles criptográficos): recomienda que controles criptográficos se utilicen de acuerdo con la legislación vigente.

La categoría 15.2 (cumplimiento de las normas y políticas para la seguridad de la información y cumplimiento técnico) tiene por objeto garantizar la conformidad de los sistemas con las políticas y normas organizacionales de seguridad de la información. Sus controles son:

- » 15.2.1 (cumplimiento con las políticas y normas de seguridad de la información): recomienda que los gestores garanticen que todos los procedimientos de seguridad de la información dentro de su área están funcionando correctamente,
- » 15.2.2 (verificación del cumplimiento técnico): considera conveniente que los sistemas de información sean verificados periódicamente para determinar el cumplimiento con las normas de implementación de la seguridad.

En la categoría 15.3 (consideraciones de la auditoría de los sistemas de información), el objetivo es maximizar la eficacia y minimizar la interferencia en el proceso de auditoría de los sistemas de información. Los controles son:

- » 15.3.1 (controles de auditoría de sistemas de información): los requisitos y las actividades de auditoría deben ser cuidadosamente planificados.
- » 15.3.2 (protección de las herramientas de auditoría de sistemas de información): se debe proteger el acceso a las herramientas de auditoría de los sistemas de información.

Ejercicio de refuerzo - sección 15: cumplimiento

Utilizando la norma, explique los controles

- » 15.1.1
- » 15.1.2
- » 15.1.4
- » 15.2.1
- » 15.3.1

Capítulo 03

Sistema de gestión de seguridad de la información

Objetivos

Presentar una visión general y el alcance del Sistema de Gestión de Seguridad de la Información, SGSI, así como un análisis crítico y detallado de los controles. También se presentará el modelo Planear, Hacer, Verificar, Actuar, PHVA.

Conceptos

Modelos SGSI y PHVA.

3.1 Visión general y alcance

El modelo del SGSI integra la estrategia de la organización y está influenciada por factores tales como:

- » Necesidades y objetivos.
- » Requisitos de seguridad.
- » Procesos.
- » Estructura organizacional.

La norma ISO/IEC 27001:2005 fue preparada para ofrecer un modelo para establecer, implementar, operar, monitorear, analizar críticamente, mantener y mejorar un SGSI.

Ejercicio de nivelación – SGSI

- » ¿Qué entiende usted por gestión?
- » ¿Qué entiende usted por sistema de gestión?

La adopción de un SGSI debe ser una decisión estratégica para la organización. La especificación y la implementación del SGSI de una organización están influenciadas por sus necesidades y objetivos, requisitos de seguridad, los procesos empleados y el tamaño y estructura de la organización.

Se espera que la implementación de un SGSI sea proporcional de acuerdo con las necesidades de la organización; por ejemplo, una situación simple requiere una solución de un SGSI sencillo.

3.2 Modelo PHVA

La norma ISO 27001 adopta el modelo conocido como PHVA, que se aplica para estructurar todos los procesos del SGSI.

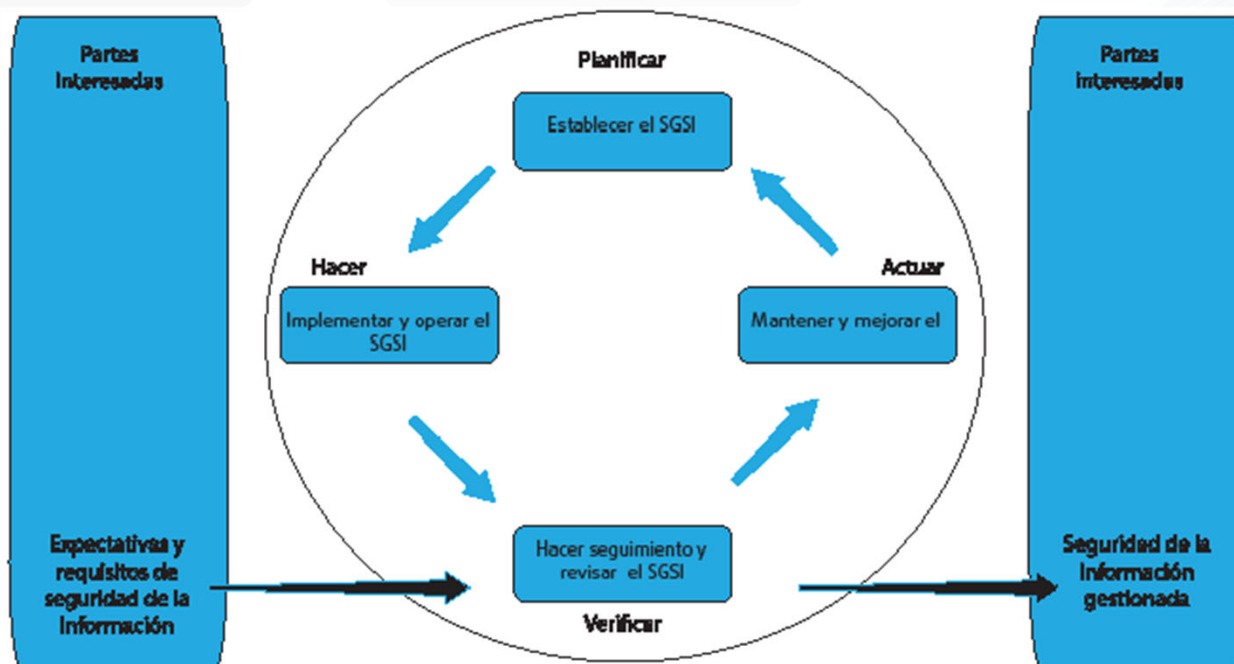


Figura 25.
Modelo PHVA

El modelo PHVA comprende un conjunto de acciones en la secuencia establecida por las letras que componen las siglas: P (plan: planear), H (hacer, ejecutar), V (verificar, controlar) y, finalmente, A (actuar, actuar de manera correctiva):

- » **Planear** (establecer el SGSI): establecer las políticas, objetivos, procesos y procedimientos del SGSI, relevantes para la gestión del riesgo y la mejora de la seguridad de información, para conseguir resultados de acuerdo con las políticas y objetivos generales de una organización.
- » **Hacer** (implementar y operar el SGSI): implementar y operar las políticas, controles, procesos y procedimientos del SGSI.
- » **Verificar** (comprobar: monitorear y analizar críticamente el SGSI): evaluar y, si es el caso, medir el desempeño de un proceso con base en la política, los objetivos y la experiencia práctica del SGSI y presentar los resultados para la revisión de la dirección.

- » **Actuar** (mantener y mejorar el SGSI): llevar a cabo las acciones correctivas y preventivas, basadas en los resultados de la auditoría interna del SGSI y el análisis crítico realizado por la dirección u otra información pertinente, para lograr la mejora continua del SGSI.

ISO/IEC 27002:2007 (Tecnología de la Información: Técnicas de Seguridad): código de práctica para la gestión de seguridad de la información. Los términos y definiciones dados en la Norma ISO/IEC 27002 son válidos y aplicables para resolver dudas.

Ejercicio de refuerzo - modelo PHVA

- » Explique el modelo PHVA.
- » Explique cómo el modelo PHVA se aplica a los SGSI. Utilice la norma para fundamentar su respuesta.

3.3 Sistema de Gestión de la Seguridad de la Información, SGSI

El SGSI en inglés *Information Security Management System*, ISMS, es un proceso estructurado de tratamiento de seguridad de la información en los diversos sectores. Ahora vamos a ver sus puntos principales para una implementación perfecta.

Para los propósitos de esta norma, el proceso utilizado se basa en el modelo PHVA. Su requisito general presenta cómo debe, la organización, obligatoriamente, tratar el proceso SGSI. Los siete verbos de acción indican cada fase o etapa del ciclo de vida del SGSI.

3.4 Estableciendo y gerenciando el SGSI

A continuación se presenta cada etapa en la gestión de un SGSI:

- » Establecer el SGSI.
- » Implementar y operar el SGSI.
- » Monitorear y analizar críticamente el SGSI.
- » Mantener y mejorar el SGSI.

3.4.1 Establecer el SGSI

Los siguientes requisitos se deben cumplir dentro de cualquier organización, al iniciar un proceso de establecimiento de un SGSI:

- » **Definir el alcance:** debe considerar las características del negocio, la organización, la ubicación, los activos y la tecnología;
- » **Definir la política de seguridad:** además de obedecer al alcance, debe fijar objetivos y establecer la dirección general para las acciones relacionadas con la seguridad. Tendrá en cuenta los requisitos legales, reglamentarios, contractuales y de negocios. La política de seguridad debe estar alineada con el contexto de la gestión del riesgo en la organización, y establecer criterios para la evaluación y ser aprobado por la dirección;
- » **Definir la estrategia de evaluación de riesgos:** determinar la metodología y desarrollar criterios para la aceptación;
- » **Hacer la identificación, análisis y evaluación de riesgos:** identificar los activos, vulnerabilidades y amenazas. Evaluar posibles daños, estimar la probabilidad y calcular el riesgo, determinando si éste es aceptable o requiere tratamiento;
- » **Identificar y evaluar las opciones para el tratamiento de los riesgos:** implementar controles, aceptar, evitar, transferir el riesgo;
- » **Seleccionar los controles y los objetivos para el tratamiento del riesgo:** seleccione los controles de la norma que han de aplicarse;
- » **Obtener aprobación para los riesgos residuales;**
- » **Obtener el consentimiento para la implementación del SGSI;**
- » **Preparar la declaración de aplicabilidad:** debe relacionar los objetivos de control y los controles seleccionados, justificando obligatoriamente aquellos no seleccionados.

Ejercicio de refuerzo - establecer el SGSI

Lea los artículos 4.2.1 y 4.2.2 de la norma NTC ISO/IEC 27001:2005.

- » Explique el requisito de definir la política de seguridad en el establecimiento de un SGSI. Utilice la norma 27001.

3.4.2 Implementación y operación del SGSI

Cumplidos los requisitos necesarios para establecer el SGSI, se debe analizar, para el ambiente de la organización, la forma de cumplir los requisitos de implementación y operación:

- » **Formular e implementar el tratamiento del riesgo:** como resultado del análisis de riesgos, la organización debe implementar un plan de tratamiento de riesgos eficiente;
- » **Implementar los controles seleccionados:** a partir de los controles identificados como necesarios para el tratamiento de los riesgos de la organización deben implementarlos;
- » **Definir parámetros para medir la eficacia de los controles:** desarrollar parámetros de medición, métricas e indicadores para evaluar la eficiencia y eficacia de los controles;
- » **Implementar un programa de entrenamiento:** poseer y poner en práctica un programa de capacitación eficaz es esencial para el éxito;
- » **Gestionar las operaciones del SGSI:** saber cómo está funcionando el SGSI y buscar áreas de mejora;
- » **Gestionar los recursos para el SGSI:** comprobar si los recursos son suficientes;
- » **Implementar controles capaces de detectar y responder a los incidentes de seguridad:** crear mecanismos de respuesta a cualquier incidente de seguridad de forma inmediata y planificada.

Ejercicio de refuerzo - implementación y operación del SGSI

- » Cite dos requisitos de implementación y operación

3.4.3 Monitoreo y análisis crítico del SGSI

Esenciales en cualquier sistema de gestión, las actividades de monitoreo y revisión son fundamentales para el éxito de un SGSI, al permitir el seguimiento, a través de evidencias, así como el proceso de mejoramiento continuo del sistema. Así tenemos, para esta fase, los siguientes requisitos:

- » **Ejecutar los procedimientos de monitoreo y análisis crítico:** detectar los errores en el procesamiento, identificar inmediatamente las fallas, brechas de seguridad e incidentes, y controlar si se llevan a cabo las actividades delegadas como fue especificado, en caso de una falla de seguridad;
- » **Llevar a cabo revisiones periódicas de la eficacia del SGSI;**
- » **Revisar el riesgo:** considerar los cambios relacionados con la organización, la tecnología, los objetivos y los procesos de negocio, las amenazas identificadas, eventos externos, tales como contratos, la legislación y el contexto social;
- » **Actualizar el plan de seguridad;**
- » **Mantenga registro de las acciones y eventos que han impactado sobre la eficacia o el rendimiento del SGSI.**

3.4.4 Mantenimiento y mejora del SGSI

Esta fase tiene como objetivo presentar los requisitos que la organización, de forma regular y estructurada, debe cumplir para que su SGSI se mantenga dentro del proceso de mejoramiento continuo del PHVA. Es interesante señalar la importancia de las acciones preventivas para este caso:

- » **Implementar las mejoras identificadas:** las acciones necesarias se han identificado en la fase anterior;
- » **Ejecutar las acciones preventivas y correctivas:** es necesario realizar acciones que puedan anticipar posibles ocurrencias;
- » **Comunicar las acciones y mejoras:** Comunicar a todos los involucrados los cambios realizados en el SGSI;
- » **Asegurar que las mejoras alcancen sus objetivos:** crear mecanismos para comprobar que se están cumpliendo los objetivos.

Ejercicio de refuerzo - mantenimiento y mejora del SGSI

Lea los artículos 4.2.3 y 4.2.4 de la norma NTC ISO/IEC 27001:2005.

- » ¿Por qué es importante esta etapa? Utilice la norma 27001 para responder.

3.5 Requisitos generales de la documentación

La documentación dentro de un SGSI es un importante factor de éxito, dado que demuestra la relación de los resultados esperados con los controles implementados. La documentación será a menudo la evidencia necesaria para averiguar que un SGSI está implementado de manera correcta y eficiente, permitiendo que las acciones puedan ser trazables y reproducibles.

Declaración de aplicabilidad:

Es un documento formal que contiene los controles aplicados, los controles no aplicados, los controles no aplicables y los controles adicionales. Se trata de una lista de todos los controles de la norma indicando: los controles aplicados y el riesgo que se está tratando, los controles no aplicados y las justificaciones para su no aplicación, y los controles no aplicables en el ambiente de la organización con sus justificaciones.

Los documentos que se enumeran a continuación son los requisitos generales obligatorios y la base documental requerida para la auditoría de un SGSI:

1. Declaración de la política de seguridad y los objetivos del SGSI;
2. Alcance;
3. Procedimientos y controles;
4. Descripción de la metodología de análisis / evaluación de riesgos;
5. Informe de análisis / evaluación de riesgos;
6. Plan de tratamiento de riesgos;
7. Procedimientos necesarios para garantizar la eficacia, la operación y los controles;
8. Descripción de la medición de la eficacia de los controles;
9. Registros requeridos.

3.6 Control de documentos

- » Aprobar la documentación.
- » Revisar, actualizar y rechazar cuando sea necesario.
- » Garantizar que los cambios y el estado de actualización estén identificados.

- » Garantizar que los documentos pertinentes están disponibles en los puntos de uso en la versión más reciente.
- » Garantizar que los documentos permanecen legibles y fácilmente identificables.
- » Garantizar que los documentos de origen externo sean identificados.
- » Garantizar que la distribución sea controlada.
- » Aplicar la debida identificación en caso de que se retengan por cualquier razón.

3.7 Control de registros

Los registros deben establecerse y mantenerse para demostrar:

- » La evidencia de la conformidad con los requisitos y la efectividad de la operación del SGSI.
- » Conformidad con las obligaciones contractuales.

Los registros deben ser solicitados durante las entrevistas de auditoría para comprobar la ejecución de los controles.



Lea los artículos 4.3.1, 4.3.2 y 4.3.3 de la norma NTC ISO/IEC 27001:2005.

Ejercicio de refuerzo - requisitos generales de la documentación

Usando la norma ISO 27001, explique las razones de la importancia de la documentación dentro de un SGSI.

3.8 Responsabilidad de la dirección

El compromiso de la dirección de la organización es fundamental para la implementación y mantenimiento del SGSI. En cualquier actividad de seguridad de la información la participación de la alta dirección es muy importante para el éxito. Por lo tanto, el compromiso de la dirección de la organización es fundamental para la implementación y mantenimiento del SGSI. Es a través de este compromiso que los otros miembros de la organización comprenden la importancia y la necesidad de consolidar un SGSI.

La organización debe determinar y proporcionar los recursos necesarios para el establecimiento y el mantenimiento del SGSI. Se deberá garantizar que todo el personal con responsabilidades definidas en el SGSI sea competente para realizar las tareas requeridas, proporcionando una formación adecuada y manteniendo un registro de competencias.



Lea el capítulo 5 de la norma NTC ISO/IEC 27001:2005.

3.9 Auditorías internas del SGSI

La organización debe realizar auditorías internas a intervalos planificados para determinar objetivos, controles, procesos y procedimientos del SGSI.

Una auditoría debe planificarse teniendo en cuenta el estado y la importancia de los procesos y las áreas a auditar, así como los resultados de las auditorías previas. Se deben definir los criterios de auditoría, su alcance, frecuencia y métodos.

3.10 Análisis crítico del SGSI

Como se ha visto anteriormente, el análisis crítico es esencial para el proceso de mejoramiento. La dirección debe analizar críticamente el SGSI a intervalos planificados para asegurarse de su conveniencia, adecuación y eficacia continua. Esta revisión debe incluir oportunidades de mejora y las necesidades de cambio del SGSI, incluyendo la política y objetivos de seguridad. Los resultados de esta revisión deben ser claramente documentados y los registros deben mantenerse.

3.11 Datos de entrada

Datos de entrada del análisis crítico:

- » Los resultados de las auditorías internas.
- » Retroalimentación de las partes interesadas.
- » Técnicas, productos o procedimientos que se pueden utilizar en la organización para mejorar el SGSI.
- » Estado de las acciones correctivas y preventivas.
- » Vulnerabilidades o amenazas no contempladas.
- » Resultado de indicadores del SGSI.
- » Acompañamiento de las acciones de las revisiones gestionadas.
- » Recomendaciones para la mejora.
- » Cualquier cambio que pueda afectar el SGSI.

Estos son datos de las evaluaciones realizadas en el período y la información obtenida a partir de nuevos análisis de riesgos, de los involucrados y de observaciones.

3.12 Datos de salida

Los datos de salida de un proceso de análisis crítico son exactamente los que tienen por objetivo la búsqueda de la excelencia en el SGSI. Debe incluir todas las acciones y decisiones que se relacionan con:

- » Mejora de la eficacia del SGSI.
- » Actualización de análisis / evaluación y plan de tratamiento de riesgos.
- » Modificación de los procedimientos y controles que afectan a la seguridad de la información.

- » La necesidad de recursos;
- » Mejoras en el control de la eficacia del SGSI.

De esta manera se cierra un ciclo de vida del SGSI. Pero no debemos olvidar que el SGSI es un sistema de procesos continuos y formalizados, con el objetivo de proporcionar un procedimiento formal para la seguridad de la información de la organización con el fin de cumplir con sus objetivos de negocio.

3.13 Mejora del SGSI

La organización debe mejorar continuamente la eficacia del SGSI mediante el uso de la política de seguridad de la información, los objetivos de seguridad, resultados de las auditorías, el análisis de los eventos monitoreados, acciones correctivas y preventivas y la revisión de la dirección.

- » **Acciones correctivas:** la organización debe tomar acciones correctivas para eliminar las causas de las no conformidades con los requisitos del SGSI para evitar su repetición.
- » **Acciones preventivas:** la organización debe determinar acciones para eliminar las causas de no conformidades potenciales con los requisitos del SGSI, para prevenir su ocurrencia.

Ejercicio de refuerzo - las mejoras del SGSI

- » De dos ejemplos de cada tipo de acción para la mejora del SGSI.

3.14 Controles detallados

La gestión de la seguridad de la información fomenta la adopción de políticas, procedimientos, directrices y otros elementos pertinentes, cuyo alcance debe comprender la gestión del riesgo sobre la base de costo/beneficio para la organización, entre ellos se encuentran:

- » Política de seguridad de la información.
- » Seguridad organizacional.
- » Gestión de activos.

- » Seguridad de los recursos humanos
- » Seguridad física y del ambiente.
- » Gestión de las operaciones y las comunicaciones.
- » Control de acceso.
- » Adquisición, desarrollo y mantenimiento de SI.
- » Gestión de incidentes de seguridad.
- » Gestión de la continuidad del negocio.

Todos los elementos son tratados en detalle en la norma ISO / IEC 27002:2007 y se explican en capítulos específicos a continuación.



Lea las secciones 7 y 8 de la norma NTC-ISO/IEC 27001:2005.



Capítulo
04

Política de seguridad de la información

Objetivos

Identificar los requisitos, construir y utilizar una política de seguridad de la información

Conceptos

Política de seguridad, normas, procedimientos y buenas prácticas.

4.1 Definición

Inicialmente, serán vistos los siguientes temas relacionados con la política de seguridad: definición, alcance y algunas cuestiones relevantes a tener en cuenta, con miras a su desarrollo y su implementación en las organizaciones.

Ejercicio de nivelación - política de seguridad de la información

- » ¿Qué entiende usted por política?
- » En su opinión, ¿cómo debería ser una política de seguridad?



Antes de comenzar este capítulo, haga una lectura completa de la sección 5: política de seguridad de la información, de la norma ISO / IEC 27002:2005. NTC ISO/IEC 27002:2007.

La política de seguridad de la información es un conjunto de lineamientos basados en unas normas y procedimientos que determinan las reglas y procedimientos a seguir para garantizar la seguridad de la información, de acuerdo con el tipo de negocio y los requisitos legales, contractuales, regulatorios y normativos aplicables a todo el alcance de la organización. Ella establecerá las directrices, límites, responsabilidades y objetivos de los controles que se deben implementar e implantar para garantizar los requisitos de protección de seguridad de la información en la organización.

Por lo tanto, la política de seguridad debe estar claramente definida, publicada, actualizada y apoyada por los dirigentes de la organización.

La importancia de la política de seguridad para el SGSI es alta, dado que representa un documento formal, incluso con valor jurídico.

4.2 Diagrama

La política de seguridad de una organización está compuesta por directrices generales que sirven como base para las normas, los procedimientos y las instrucciones relacionadas a la seguridad de la información.

Debe estar alineada con la norma ISO 27001, con la legislación vigente y las normas generales por las que se rige la organización.

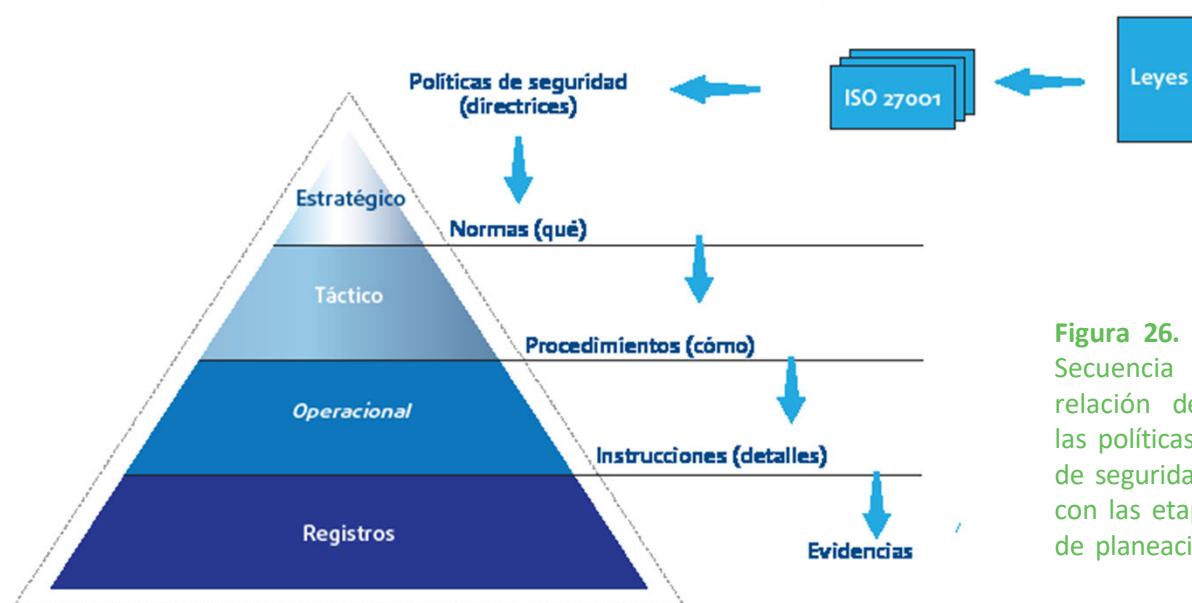


Figura 26. Secuencia y relación de las políticas de seguridad con las etapas de planeación

Tabla 1. Secuencia y relación de las políticas de seguridad con las etapas de planeación

Políticas	Directrices que se deben seguir. Responde al “por qué” realizar la seguridad de la información, definiendo directrices genéricas de lo que debe hacer la organización para lograr la seguridad de la información.
Normas	Reglas básicas de cómo debe ser implementado el control o conjunto de controles, que se definieron en las políticas. Responden “qué” hacer para alcanzar las directrices definidas en la política de seguridad.
Procedimientos	Actividades detalladas sobre cómo deben ser implementados los controles o conjunto de controles. Responde “cómo” hacer cada elemento definido en las normas específicas y sus políticas.
Instrucciones	Descripción de una operación o conjunto de operaciones para la ejecución de la implementación de los controles de seguridad de la información.
Evidencias	Mecanismos adoptados para permitir la recolección y verificación de la aplicación de los controles de seguridad de la información, su eficacia y eficiencia. Permite la trazabilidad y su uso en auditorías.

Ejercicio de refuerzo - diagrama

¿Cuáles son los procedimientos formales existentes en el departamento de las TI de su organización?

4.3 Arquitectura de políticas de seguridad

No existe una arquitectura estándar para la definición de políticas de seguridad. Ellas deben seguir y cumplir los requisitos de negocio de la organización y su cultura organizacional. Para una buena estructuración de las políticas de seguridad se puede tener como base las dimensiones de la seguridad de la información presentada en el libro “Practicando la Seguridad de la Información”:



Fuente: Fontes (2012)

Figura 27.
Estructura basada en la Norma Internacional ISO/IEC 27002:2007

Estas pueden ser vistas como las políticas de seguridad necesarias, pero que deben ser adecuadas a las necesidades de cada organización. Es fundamental que cada organización establezca la arquitectura que necesita tener para cumplir con los requisitos de seguridad y de negocios.

4.4 Alcance

En una organización, la política de seguridad debe:

- » Establecer los principios a seguir con el fin de proteger, controlar y monitorear sus recursos y su información;
- » En particular, la política de seguridad de la información puede ser integrada a otras políticas y planes existentes en la organización, como las políticas de contingencia y el plan estratégico de negocios.
- » Al definir el alcance de la política, detallar los límites de su aplicación, citando los ambientes físicos, lógicos y organizacionales que son aplicables y tipos de usuarios, entre otros.

Ejercicio de refuerzo - alcance

- » ¿Qué nivel de detalle es necesario para definir el alcance de la política de seguridad de su organización?

4.5 Preguntas importantes

Con el objetivo de definir una política de seguridad de la información para una organización, se debe tener en cuenta las respuestas a las siguientes preguntas:

- » ¿Qué desea proteger? Activos de la organización que requieren protección.
- » ¿Contra qué o quién? ¿Cuáles son las amenazas que pueden afectar a la organización y cómo y por quién estas amenazas pueden ser explotados?
- » ¿Cuáles son las amenazas más probables? Identificar las amenazas que tienen más posibilidades de ocurrir.
- » ¿Cuál es la relevancia de cada recurso a ser protegido? Importancia del recurso dentro del proceso de negocio.
- » ¿Cuál es el grado de protección requerido? Requisitos de protección que el negocio requiere. ¿Qué nivel de protección es necesario?
- » ¿Cuánto tiempo, recursos financieros y humanos están a disposición? ¿Cuáles recursos están disponibles para fines de seguridad? ¿Qué se puede hacer con los recursos existentes?
- » ¿Cuáles son las expectativas de los usuarios y clientes? ¿Qué espera usted de la seguridad de la información para el negocio de la organización, servicios y productos?

Así, se pueden aplicar mecanismos de seguridad adecuados a los requisitos de seguridad indicados por la política. Además, con las respuestas adecuadas, se puede analizar los riesgos y los requisitos legales y de normas, de acuerdo con la política de seguridad.

6. Etapas

La política de seguridad debe implantarse de acuerdo con un proceso formal, pero flexible, para permitir cambios de acuerdo a las necesidades. Una propuesta típica para la implementación de una política de seguridad de la información comprende:

- » Identificar las leyes aplicables a la organización;
- » Identificar los recursos críticos;
- » Clasificar la información de la organización, no sólo observando el área de informática, sino todos los sectores y su información;
- » Analizar las necesidades de seguridad, con el objetivo de identificar las posibles amenazas, los riesgos y los impactos en la organización;
- » Preparar la propuesta de la política de seguridad;
- » Discutir abiertamente con todos los involucrados el contenido de la propuesta presentada;
- » Aprobar la política de seguridad;
- » Implementar la política de seguridad;
- » Hacer mantenimiento, regularmente, de la política de seguridad, buscando identificar las mejoras necesarias y hacer las revisiones necesarias.

A continuación se detallan cada uno de los pasos mencionados.

1. Identificar la legislación

Cada organización está sujeta a diversas leyes, reglamentos, normas de la agencia reguladora en su área de negocio, que deben seguirse y cumplirse bajo el riesgo de sanciones en caso de incumplimiento. Por lo tanto, es importantísimo el levantamiento de toda la legislación con el fin de evitar que las políticas de seguridad atenten contra alguna de ellas.

Ejercicio de refuerzo - identificar la legislación.

¿Cuál es la importancia de la identificación de la legislación para el desarrollo de la política de seguridad?

4.6.2 Identificación de los recursos críticos

La primera fase del proceso de implementación de una política de seguridad incluye la identificación de los recursos críticos de la organización, es decir, los recursos sujetos a riesgos de seguridad.

Por ejemplo, teniendo en cuenta los escenarios de tecnología de la información, se presentan los siguientes recursos como críticos:

- » Hardware, tales como servidores, equipos de interconexión (*routers, switches*, etc), las líneas de comunicación, etc.;
- » Software, tales como sistemas operativos, aplicaciones, herramientas de ayuda a actividades de negocio, utilidades, etc.;
- » Datos (procesamiento o transmisión), copias de seguridad, *logs*, bases de datos, etc.;
- » Personas, en términos de los usuarios (internos y externos, según sea el caso), empleados y dirigentes;
- » Documentación relativa a software, sistemas de información, entre otros;
- » Suministros, tales como papel, cintas, CDs / DVDs, etc.

Considerando un escenario diferente, otro tipo de recursos se pueden plantear.

Ejercicio de refuerzo - identificación de los recursos críticos

¿Nombre dos recursos fundamentales de su organización que se deben tener en cuenta en el desarrollo de la política de seguridad?

4.6.3 Análisis de requisitos de seguridad

Al analizar las necesidades de seguridad, se debe considerar el análisis de riesgos, en particular, las amenazas e impactos con el fin de determinar los elementos críticos de la organización, sus costos asociados y el nivel de seguridad adecuado.

Un análisis de riesgos completo y preciso es el punto clave para una apropiada política de seguridad de una organización, y por lo tanto para la gestión de la seguridad de la información. La gestión del riesgo se

detallará en los capítulos 6 y 7, que incluyen más información sobre el análisis de riesgos.

Otro punto a destacar son las recomendaciones de buenas prácticas en el ámbito de la seguridad de la información. El seguimiento de estas buenas prácticas ayudará a que la organización sea vista como preocupada por la seguridad de su información.

4.6.4 Preparación de la propuesta y la discusión abierta

La propuesta de una política de seguridad de una organización debe estar elaborada con base en el estudio de los recursos críticos y en el análisis de las necesidades de seguridad realizadas previamente para que, así, los objetivos de seguridad sean identificados de manera adecuada, de acuerdo con el negocio y los riesgos involucrados en la organización.

La política de seguridad debe, normalmente, ser desarrollada y presentada por el comité para la seguridad de la información. Este comité está integrado por representantes de diversas áreas, principalmente el área jurídica, de las TI y de recursos humanos, y debe tener un período establecido.

Una vez elaborada, la propuesta debe ser discutida abiertamente con todo el personal directamente involucrado con el asunto, en particular, con los dirigentes de la organización, teniendo en cuenta su apoyo es crucial para la implementación de la política de seguridad.

Ejercicio de refuerzo – preparación de la propuesta

- » ¿Quién va a desarrollar la política de seguridad de su organización?

4.7 Documentación

La política de seguridad de una organización debe ser documentada, y el documento generado debe ser aprobado por sus dirigentes para que pueda ser publicado y difundido a todos los involucrados. Vale la pena mencionar la necesidad de alinear la política de seguridad con los objetivos y estrategias de negocio de la organización.

La política de seguridad debe contener, por recomendación de la norma ISO/IEC 27002:2007, los siguientes elementos:

- » La definición de seguridad de la información, sus objetivos, el alcance y relevancia para la organización;
- » Declaración del compromiso de los líderes de la política de seguridad de la organización;
- » Indicación de los objetivos de control y de los controles, incluyendo el análisis / evaluación y la gestión del riesgo;
- » Breve explicación acerca de las políticas, principios, normas y requisitos para garantizar la conformidad con la legislación, reglamentos, contratos y normas de seguridad;
- » Definición de las responsabilidades con la gestión de seguridad de la información;
- » Las referencias a los documentos que sustentan la política de seguridad.

Es de destacar que la política de seguridad puede estar compuesta por una serie de políticas específicas, como la política de contraseñas, *backup*, etc.

4.8 Aprobación e implementación

La fase de aprobación de la política de seguridad corresponde al resultado positivo obtenido tras el análisis de la propuesta elaborada y presentada a la organización. En particular, ésta exige el apoyo de los líderes de la organización como una forma de asegurar los primeros pasos hacia la implementación de la política de seguridad y las condiciones adecuadas para su mantenimiento.

En la implementación deben ser considerados todos los aspectos relacionados con la implementación de mecanismos de seguridad (soluciones técnicas, administrativas, etc.) apropiados para garantizar que

las necesidades de seguridad levantadas previamente son atendidas adecuadamente.

Ejercicio de refuerzo –aprobación e implementación

- » ¿Quién va a aprobar la política de seguridad de su organización?

9. Comunicación de la política y entrenamiento

La divulgación de la política de seguridad y su comunicación a toda la organización es otro aspecto importante de su implementación en la organización. Se recomienda, a propósito, que la divulgación haga parte de la formación de los empleados nuevos y de la actualización de los antiguos, además de que se realicen periódicamente. Esta política de divulgación debe ser formal y efectiva, indicando todos los detalles de su implementación, cómo debe ser cumplida y las sanciones, en caso de incumplimiento. Recuerde que la mejor medida de prevención es la educación.

10. Mantenimiento

La política de seguridad de la información adoptada en una organización debe analizarse periódicamente (se recomienda anualmente), con el objetivo de mantener su idoneidad y su eficiencia. También debe ser revisado en caso de cambios significativos en cuanto a los negocios y avances tecnológicos. En el análisis se busca:

- » Las mejoras a la política misma, mejoras en los controles, la asignación de recursos y la asignación de responsabilidades;
- » Responder a los cambios del negocio, los recursos disponibles, condiciones técnicas y tecnológicas;
- » Presentar una respuesta a los cambios que afectan directamente el modo de gerencia de la seguridad de la información;
- » Responder a los cambios en los aspectos contractuales, reglamentarios y legales;
- » Atender las recomendaciones de las autoridades u organismos competentes.

Se recomienda que este análisis sea realizado por un empleado o equipo responsable de la gestión de la política de seguridad. A continuación, se debe generar el nuevo documento de la política de seguridad, y este, a su vez, debe ser reconocido y apoyado por los líderes de la organización.

Ejercicio de refuerzo – mantenimiento

- » ¿Cómo definir el tiempo para el mantenimiento de una política de seguridad?

4.11 Buenas prácticas

La política de seguridad tiene un papel clave en las organizaciones y, por eso, se recomienda que se considere como un conjunto de reglas que se deben seguir fielmente y se deben gestionar de manera adecuada. Por lo tanto, es evidente la relación entre la gestión de la seguridad de la información y la política de seguridad de una organización.

Para obtener mejores resultados se recomiendan las siguientes buenas prácticas, al considerar la política de seguridad de una organización:

- » La alta dirección de la organización debe apoyar y creer que las políticas de seguridad de la información van a proteger su información. Por lo tanto, el patrocinio de la alta dirección es importante para que se cumplan los objetivos de la política de seguridad. Este apoyo debe comenzar con el desarrollo de la política, pasar por su firma y divulgación, llegando al mantenimiento de la eficiencia y su actualización.
- » No siempre es posible detectar una violación de la política de seguridad, sin embargo, en situaciones donde hay una posibilidad, es importante identificar la causa en primera instancia como por ejemplo un error, negligencia, desconocimiento de la política, etc. Por otra parte, se recomienda que en la política de seguridad que establezcan los procedimientos a seguir si se produce una violación, según su gravedad, determinando también las acciones correctivas necesarias y sanciones a los responsables directos del problema. Tenga en cuenta que, como ya se mencionó en el capítulo 2, el castigo puede variar dependiendo de la ofensa y puede ser tratado legalmente; sin

- embargo, la organización deberá divulgar la política de seguridad, la legislación vigente y las responsabilidades específicas de todos sus empleados .
- » Es saludable establecer una estructura organizativa responsable de la seguridad de la información en la organización, con el fin de determinar las personas responsables de la aprobación, revisión y gestión de la implementación de la política de seguridad en la organización. Tales actividades pueden ser realizadas por un empleado o equipo.
 - » Se debe trabajar la seguridad del personal para minimizar o incluso evitar los problemas de seguridad de la información con causa proveniente de errores humanos.

Todos los miembros de la organización deben tener conocimiento sobre los riesgos para la seguridad y sus responsabilidades con el aspecto de seguridad. Para eso, se recomienda siempre la difusión de buenas prácticas, las normas, las leyes y normas vigentes.

4.12 Otras buenas prácticas

El control y la clasificación de los recursos informáticos de la organización son relevantes. La clasificación se lleva a cabo de acuerdo con las condiciones críticas del recurso para el negocio. En particular, se debe asociar cada recurso a un responsable directo en la organización.

La implementación del control de acceso lógico y físico para establecer los límites de acceso son recomendados, utilizando dispositivos de control de entrada y salida. En cuanto a los recursos computacionales y otros activos de la organización, es importante administrarlos de acuerdo a las exigencias actuales de seguridad de la información.

La auditoría de seguridad de la información debe ser una actividad periódica de la organización con el fin de verificar si la política de seguridad es eficiente y si hay necesidad de actualizaciones.

4.13 Buenas prácticas para escribir el texto de la política

- » **Definir el objetivo del documento:** describa cuál es el objetivo del documento y lo que la organización quiere comunicar con el documento de la política.
- » **Use textos cortos y objetivos:** escritos en el lenguaje del público de la organización. Sea claro en el mensaje que desea transmitir, para que el texto sea entendido por todos. Sea explícito y no deje dudas o incertidumbres.
- » **Definir los roles y responsabilidades con respecto a la política de seguridad.**
- » **Evitar el uso de términos técnicos o lengua extranjera:** nadie está obligado a conocer la terminología técnica que no se usa su área de especialización.
- » **Evitar el uso de “no”:** si es necesario, utilice “está prohibido”, “negar”, “está vetado”, entre otros.
- » **Evitar el uso de “excepto” o “en principio”:** estos términos crean oportunidad para disculpas por incumplimiento.
- » **Crear en la política un elemento para las definiciones y los conceptos:** definir en el principio del documento todos los conceptos, definiciones, términos técnicos y acrónimos que se utilizarán en la política.
- » **Penalización:** definir las posibles sanciones para aquellos usuarios que no cumplan con la política. Solicitar la colaboración de la oficina jurídica y recursos humanos.
- » **Crear reglas y recomendaciones factibles de ser implementadas y cumplidas por toda la organización y en todos los niveles jerárquicos.**
- » **Tenga cuidado con la estructura gramatical:** las políticas deben ser ejemplo de un texto escrito correctamente. Evite los modismos y los términos de doble sentido.
- » **Solicitar que la oficina jurídica evalúe el documento y certifique su aceptación.**